

# **CYMANABU**

Cybersecurity Internship Program

## **WEEK 3 TASK SUBMISSION**

**Cybersecurity – VULNERABILITY ASSESSMENT**

**Using Nessus**

**Tools Used**

**Kali Linux | Metasploitable 2 | VMware | Nessus**

**Submitted By: Saif**

Sami

**College: Oriental**

College of Technology

**Branch: Cybersecurity**

**Internship: Cybersecurity Internship**

# **TABLE OF CONTENTS**

1. Overview
2. Objective
3. Tools Used
4. Lab Setup
5. Nmap Discovery
6. Nessus Installation and Configuration
7. Nessus Scan Configuration
8. Nessus Scan Execution
9. Vulnerability Findings
10. Detailed Vulnerability Analysis
11. Finding Verification
12. Risk Analysis
13. Remediation Recommendations
14. Key Learnings
15. Conclusion
16. References
17. Appendix – Screenshots and Evidence

# 1. OVERVIEW

Vulnerability assessment is an important cybersecurity process used to identify, analyze, and document security weaknesses in computer systems, networks, applications, and services.

As part of this practical assignment, a vulnerability assessment was performed in an authorized and isolated VMware laboratory environment. Kali Linux was used as the assessment machine, while Metasploitable 2 was used as the intentionally vulnerable target system.

Nmap was first used to discover the target system and identify its exposed network services and software versions. After the initial reconnaissance, Tenable Nessus was configured on Kali Linux and used to perform an automated vulnerability assessment against the target.

The Nessus scan generated multiple security findings with different severity levels. The findings were reviewed based on vulnerability descriptions, affected services, CVE information where available, severity, and supporting evidence. Important findings were also compared with the Nmap service-discovery results to improve confidence in the assessment.

This practical provided hands-on experience with vulnerability scanning, service enumeration, CVE analysis, security risk identification, evidence collection, verification, and remediation planning.

## 2. OBJECTIVE

The main objectives of this vulnerability assessment practical are:

- To understand the basic process of vulnerability assessment.
- To configure and use Nessus for automated vulnerability scanning.
- To identify active services and software versions on an intentionally vulnerable system.
- To perform service and version discovery using Nmap.
- To identify security vulnerabilities, associated CVEs, and severity levels.
- To collect and document technical evidence for identified vulnerabilities.
- To verify important vulnerability findings using available service and version information.
- To analyze the possible security impact of identified vulnerabilities.
- To recommend suitable remediation measures such as patching, disabling unnecessary services, and restricting network access.
- To develop professional vulnerability assessment documentation based on practical results.

### 3. TOOLS USED

The following tools and technologies were used during the vulnerability assessment practical:

- 1. Kali Linux**

Used as the primary cybersecurity assessment platform for running Nmap and Nessus.

- 2. Tenable Nessus Essentials**

Used to perform automated vulnerability scanning and identify security weaknesses in the target system.

- 3. Nmap**

Used for host discovery, open-port scanning, service detection, and software version identification.

- 4. Metasploitable 2**

Used as an intentionally vulnerable target machine for security testing and vulnerability assessment.

- 5. VMware**

Used to create and manage the isolated virtual laboratory environment.

- 6. Firefox Web Browser**

Used to access and configure the Nessus web interface through HTTPS.

- 7. Linux Terminal**

Used to execute Nmap, Nessus, networking, and system-verification commands.

## 4.LAB SETUP

The vulnerability assessment was performed in an isolated VMware laboratory environment. The lab consisted of two virtual machines connected through the same virtual network.

The Kali Linux virtual machine was used as the security assessment system. Nessus and Nmap were executed from Kali Linux to identify and assess vulnerabilities.

Metasploitable 2 was used as the target machine. It is an intentionally vulnerable Linux-based virtual machine designed for cybersecurity education and security testing.

### LAB NETWORK DETAILS

Scanner Machine:

- Operating System: Kali Linux
- IP Address: 192.168.52.128
- Interface: eth0
- Role: Vulnerability Assessment Scanner

Target Machine:

- Operating System: Metasploitable 2
- IP Address: 192.168.52.129
- Role: Intentionally Vulnerable Target

Virtualization Platform:

- VMware
- Network Type: Isolated Virtual Lab Network

The connectivity between Kali Linux and Metasploitable 2 was verified before starting the assessment. The target responded successfully to ICMP ping requests, confirming that both systems were reachable over the laboratory network.

The assessment was restricted to the authorized Metasploitable 2 laboratory machine and was not performed against any external or production system.

### 4.1. Network Connectivity Verification

Before performing the vulnerability assessment, network connectivity between the Kali Linux machine and the Metasploitable 2 target machine was verified. Both virtual machines were configured on the same VMware virtual network. The connectivity was tested using IP address verification, ICMP ping, and Nmap host discovery.

#### 4.1.1 Kali Linux IP Address Verification

The IP address of the Kali Linux machine was checked using the *ip addr* command. The Kali Linux system was assigned the IP address **192.168.52.128/24** on the eth0 interface.

```
kali@kali: ~  
File Actions Edit View Help  
C:\home\kali> ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN  
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
   inet 127.0.0.1/8 scope host lo  
       valid_lft forever preferred_lft forever  
   inet6 ::1/128 scope host noprefixroute  
       valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel  
   link/ether 00:0c:29:50:f9:47 brd ff:ff:ff:ff:ff:ff  
   inet 192.168.52.128/24 brd 192.168.52.255 scope global dynamic  
       valid_lft 1711sec preferred_lft 1711sec  
   inet6 fe80::4d34:f7ce:62be:3e1f/64 scope link noprefixroute  
       valid_lft forever preferred_lft forever  
  
C:\home\kali> ping -c 4 192.168.52.129  
PING 192.168.52.129 (192.168.52.129) 56(84) bytes of data.  
64 bytes from 192.168.52.129: icmp_seq=1 ttl=64 time=1.43 ms
```

Figure 1: Kali Linux IP address configuration

#### 4.1.2 Metasploitable 2 IP Address Verification

The IP address of the Metasploitable 2 machine was verified using the *ifconfig* command. The target machine was assigned the IP address **192.168.52.129**.

```
msfadmin@metasploitable:~$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue  
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
   inet 127.0.0.1/8 scope host lo  
       inet6 ::1/128 scope host  
       valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000  
   link/ether 00:0c:29:00:d3:8c brd ff:ff:ff:ff:ff:ff  
   inet 192.168.52.129/24 brd 192.168.52.255 scope global eth0  
       inet6 fe80::20c:29ff:fe00:d38c/64 scope link  
       valid_lft forever preferred_lft forever  
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000  
   link/ether 00:0c:29:00:d3:96 brd ff:ff:ff:ff:ff:ff
```

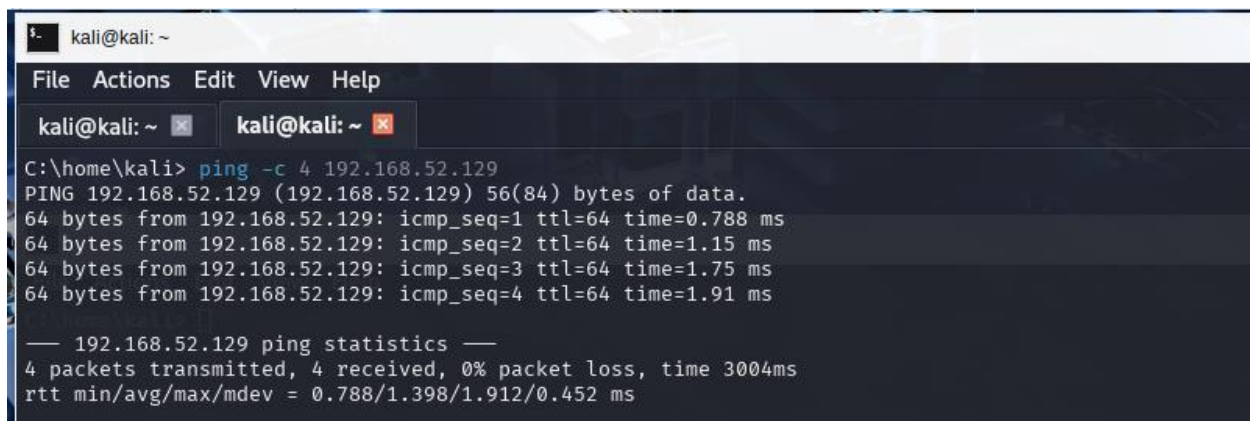
Figure 2: Metasploitable 2 IP address configuration

#### 4.1.3 ICMP Ping Connectivity Test

An ICMP ping test was performed from Kali Linux to Metasploitable 2 using the following command:

```
ping -c 4 192.168.52.129
```

The target responded successfully to all four ICMP requests, confirming that Kali Linux could communicate with Metasploitable 2 over the configured virtual network.



```
kali@kali: ~  
File Actions Edit View Help  
kali@kali: ~ kali@kali: ~  
C:\home\kali> ping -c 4 192.168.52.129  
PING 192.168.52.129 (192.168.52.129) 56(84) bytes of data.  
64 bytes from 192.168.52.129: icmp_seq=1 ttl=64 time=0.788 ms  
64 bytes from 192.168.52.129: icmp_seq=2 ttl=64 time=1.15 ms  
64 bytes from 192.168.52.129: icmp_seq=3 ttl=64 time=1.75 ms  
64 bytes from 192.168.52.129: icmp_seq=4 ttl=64 time=1.91 ms  
  
— 192.168.52.129 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3004ms  
rtt min/avg/max/mdev = 0.788/1.398/1.912/0.452 ms
```

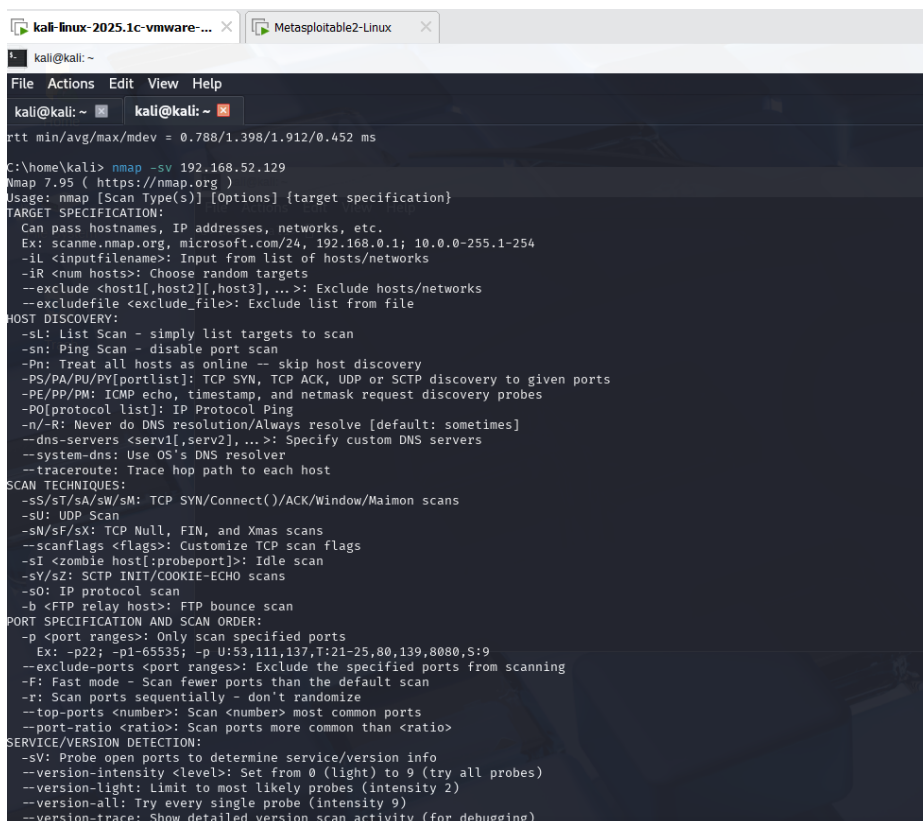
Figure 3: Successful ICMP connectivity between Kali Linux and Metasploitable 2

#### 4.1.4 Nmap Host Discovery

Nmap was used to verify whether the Metasploitable 2 machine was reachable and active on the network. The following command was executed from Kali Linux:

```
nmap -sn 192.168.52.129
```

The scan identified the target as an active host, further confirming network connectivity between the two virtual machines.



```
kali@kali: ~  
File Actions Edit View Help  
kali@kali: ~ kali@kali: ~  
rtt min/avg/max/mdev = 0.788/1.398/1.912/0.452 ms  
C:\home\kali> nmap -sn 192.168.52.129  
Nmap 7.95 ( https://nmap.org )  
Usage: nmap [Scan Type(s)] [Options] {target specification}  
TARGET SPECIFICATION:  
  Can pass hostnames, IP addresses, networks, etc.  
  Ex: scanme.nmap.org, microsoft.com/24, 192.168.0.1; 10.0.0-255.1-254  
  -iL <inputfilename>: Input from list of hosts/networks  
  -iR <num hosts>: Choose random targets  
  --exclude <host1[,host2][,host3],...>: Exclude hosts/networks  
  --excludefile <exclude_file>: Exclude list from file  
HOST DISCOVERY:  
  -sL: List Scan - simply list targets to scan  
  -sn: Ping Scan - disable port scan  
  -Pn: Treat all hosts as online -- skip host discovery  
  -PS/PA/PU/PP[<portlist>]: TCP SYN, TCP ACK, UDP or SCTP discovery to given ports  
  -PE/PP/PM: ICMP echo, timestamp, and netmask request discovery probes  
  -PO[<protocol list>]: IP Protocol Ping  
  -n/-R: Never do DNS resolution/Always resolve [default: sometimes]  
  --dns-servers <serv1[,serv2],...>: Specify custom DNS servers  
  --system-dns: Use OS's DNS resolver  
  --traceroute: Trace hop path to each host  
SCAN TECHNIQUES:  
  -sS/sT/sA/sW/sM: TCP SYN/Connect()/ACK/Window/Maimon scans  
  -sU: UDP Scan  
  -sN/sF/sX: TCP Null, FIN, and Xmas scans  
  --scanflags <flags>: Customize TCP scan flags  
  -sI <zombie host[:probeport]>: Idle scan  
  -sV/sZ: SCTP INIT/COOKIE-ECHO scans  
  -sO: IP protocol scan  
  -b <FTP relay host>: FTP bounce scan  
PORT SPECIFICATION AND SCAN ORDER:  
  -p <port ranges>: Only scan specified ports  
    Ex: -p22; -p1-65535; -p U:53,I:137,T:21-25,80,139,8080,S:9  
  --exclude-ports <port ranges>: Exclude the specified ports from scanning  
  -F: Fast mode - Scan fewer ports than the default scan  
  -r: Scan ports sequentially - don't randomize  
  --top-ports <number>: Scan <number> most common ports  
  --port-ratio <ratio>: Scan ports more common than <ratio>  
SERVICE/VERSION DETECTION:  
  -sV: Probe open ports to determine service/version info  
  --version-intensity <level>: Set from 0 (light) to 9 (try all probes)  
  --version-light: Limit to most likely probes (intensity 2)  
  --version-all: Try every single probe (intensity 9)  
  --version-trace: Show detailed version scan activity (for debugging)
```

Figure 4: Nmap host discovery confirming Metasploitable 2 is reachable

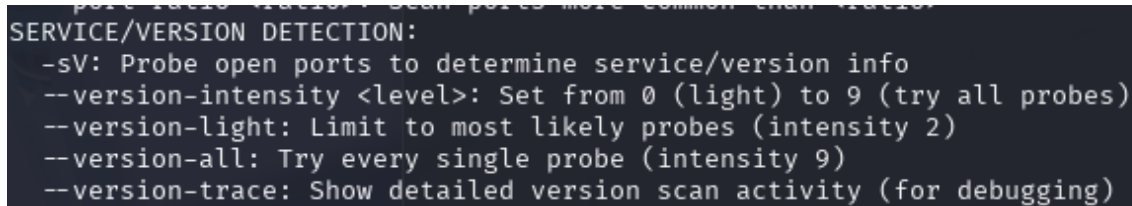


#### 4.1.5 Nmap Service and Version Detection

After confirming connectivity, Nmap service and version detection was performed against the Metasploitable 2 target using:

```
nmap -sV 192.168.52.129
```

The scan identified multiple open ports and associated services running on the target machine. These services were later used as input for the vulnerability assessment process.

A screenshot of a terminal window showing the output of the Nmap -sV command. The text is as follows:

```
port 14444/tcp: Scan ports more common than 14444
SERVICE/VERSION DETECTION:
-sV: Probe open ports to determine service/version info
--version-intensity <level>: Set from 0 (light) to 9 (try all probes)
--version-light: Limit to most likely probes (intensity 2)
--version-all: Try every single probe (intensity 9)
--version-trace: Show detailed version scan activity (for debugging)
```

*Figure 5: Nmap service and version detection of Metasploitable 2*

#### 4.1.6 Result

The network connectivity between Kali Linux (**192.168.52.128**) and Metasploitable 2 (**192.168.52.129**) was successfully verified. The successful ICMP ping confirmed basic network communication, while Nmap host discovery confirmed that the target system was active. Service and version detection was then performed to identify the exposed services on Metasploitable 2. The connectivity verification was completed successfully before proceeding with the Nessus vulnerability assessment.

## 5. NMAP DISCOVERY

Nmap was used as the initial reconnaissance and service-discovery tool to identify the active services and software versions running on the Metasploitable 2 target.

The following command was executed from Kali Linux:

```
nmap -sV 192.168.52.129 -oN nmap-initial.txt
```

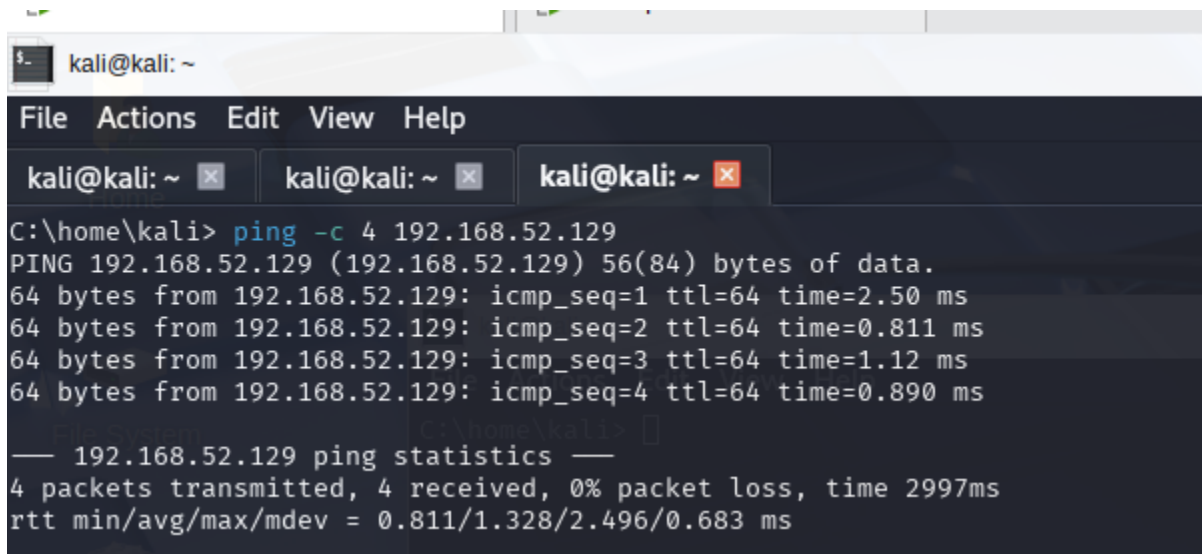
The `-sV` option was used to detect service and software versions, while the `-oN` option saved the scan results in normal text format.

The scan confirmed that the target host **192.168.52.129** was active and exposed multiple network services. The scan identified services including FTP, SSH, Telnet, SMTP, DNS, HTTP, SMB, MySQL, PostgreSQL, VNC, IRC, Apache Tomcat, and other network services.

### 5.1 Nmap Service and Version Discovery

The Nmap scan was performed from Kali Linux against the Metasploitable 2 target using the following command:

```
nmap -sV 192.168.52.129 -oN nmap-initial.txt
```



```
kali@kali: ~  
File Actions Edit View Help  
kali@kali: ~ x kali@kali: ~ x kali@kali: ~ x  
C:\home\kali> ping -c 4 192.168.52.129  
PING 192.168.52.129 (192.168.52.129) 56(84) bytes of data.  
64 bytes from 192.168.52.129: icmp_seq=1 ttl=64 time=2.50 ms  
64 bytes from 192.168.52.129: icmp_seq=2 ttl=64 time=0.811 ms  
64 bytes from 192.168.52.129: icmp_seq=3 ttl=64 time=1.12 ms  
64 bytes from 192.168.52.129: icmp_seq=4 ttl=64 time=0.890 ms  
  
— 192.168.52.129 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 2997ms  
rtt min/avg/max/mdev = 0.811/1.328/2.496/0.683 ms
```

*Figure 2: Nmap service and version discovery results – Part 1*

The first part of the scan confirmed that the target host was active and identified several open services, including FTP, SSH, Telnet, SMTP, DNS, HTTP, RPCbind, and SMB.

```

C:\home\kali> nmap -sV 192.168.52.129 -oN nmap-initial.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-01 01:23 EDT
Nmap scan report for 192.168.52.129
Host is up (0.0048s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:00:D3:8C (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.79 seconds

```

Figure 3: Nmap service and version discovery results – Part 2

The remaining results identified additional services such as Java RMI, NFS, ProFTPD, MySQL, PostgreSQL, VNC, X11, IRC, AJP13, and Apache Tomcat.

## 5.2 Key Nmap Findings

The following services and ports were identified during the Nmap scan:

| Port | Service | Version / Information |
|------|---------|-----------------------|
| 21   | FTP     | vsftpd 2.3.4          |
| 22   | SSH     | OpenSSH 4.7p1         |
| 23   | Telnet  | Linux telnetd         |
| 25   | SMTP    | Postfix smtpd         |
| 53   | DNS     | ISC BIND 9.4.2        |
| 80   | HTTP    | Apache httpd 2.2.8    |
| 111  | RPCbind | RPC #100000           |
| 139  | SMB     | Samba smbd            |

| <b>Port</b> | <b>Service</b> | <b>Version / Information</b> |
|-------------|----------------|------------------------------|
| 445         | SMB            | Samba smbd                   |
| 512         | Rexec          | netkit-rsh rexecd            |
| 513         | Rlogin         | OpenBSD/Solaris rlogind      |
| 514         | TCP Wrapped    | TCP wrapped service          |
| 1099        | Java RMI       | GNU Classpath grmiregistry   |
| 1524        | Bindshell      | Metasploitable root shell    |
| 2049        | NFS            | NFS 2–4                      |
| 2121        | FTP            | ProFTPD 1.3.1                |
| 3306        | MySQL          | MySQL 5.0.51a                |
| 5432        | PostgreSQL     | PostgreSQL 8.3.x             |
| 5900        | VNC            | VNC protocol 3.3             |
| 6000        | X11            | X11                          |
| 6667        | IRC            | UnrealIRCd                   |
| 8009        | AJP13          | Apache Jserv                 |
| 8180        | HTTP           | Apache Tomcat/Coyote         |

```

C:\home\kali> ls -l nmap-initial.txt
-rw-rw-r-- 1 kali kali 1774 Oct  1 01:23 nmap-initial.txt

C:\home\kali> cat nmap-initial.txt
# Nmap 7.95 scan initiated Thu Oct  1 01:23:37 2026 as: /usr/lib/nmap/nmap --privileged -sV -oN nmap-initial.txt 192.168.52.129
Nmap scan report for 192.168.52.129
Host is up (0.0048s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:00:D3:8C (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Oct  1 01:23:50 2026 -- 1 IP address (1 host up) scanned in 13.79 seconds

```

Figure 4: Nmap open ports and identified services

### 5.3 Nmap Scan Result

The Nmap scan identified **23 open TCP ports** on the Metasploitable 2 target. The target host was confirmed to be active, and service and version detection provided information about the software exposed on the system.

The Nmap results provided the initial attack-surface information required for the subsequent Nessus vulnerability assessment. The discovered services were later compared with the services identified by Nessus to support verification of the vulnerability assessment findings.

## 6. NESSUS INSTALLATION AND CONFIGURATION

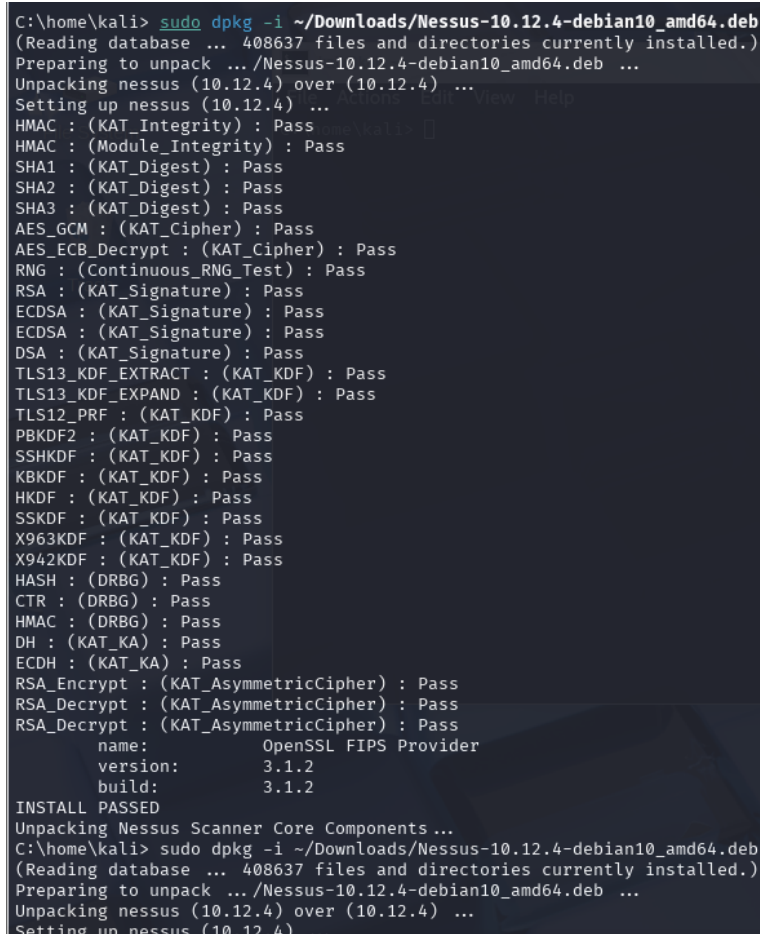
Tenable Nessus was installed and configured on the Kali Linux assessment machine. Nessus was selected as the vulnerability assessment tool because it can perform automated security checks and provide detailed vulnerability information.

### 6.1 Nessus Package Installation

The Nessus Debian package was installed on the Kali Linux system using the following command:

```
sudo dpkg -i Nessus-10.12.4-debian10_amd64.deb
```

The installation completed successfully and the Nessus package was registered on the Kali Linux system.



```
C:\home\kali> sudo dpkg -i ~/Downloads/Nessus-10.12.4-debian10_amd64.deb
(Reading database ... 408637 files and directories currently installed.)
Preparing to unpack .../Nessus-10.12.4-debian10_amd64.deb ...
Unpacking nessus (10.12.4) over (10.12.4) ...
Setting up nessus (10.12.4) ...
HMAC : (KAT_Integrity) : Pass
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RNG : (Continuous_RNG_Test) : Pass
RSA : (KAT_Signature) : Pass
ECDSA : (KAT_Signature) : Pass
ECDSA : (KAT_Signature) : Pass
DSA : (KAT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass
TLS13_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SSHKDF : (KAT_KDF) : Pass
KDKDF : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
name:      OpenSSL FIPS Provider
version:   3.1.2
build:     3.1.2
INSTALL PASSED
Unpacking Nessus Scanner Core Components...
C:\home\kali> sudo dpkg -i ~/Downloads/Nessus-10.12.4-debian10_amd64.deb
(Reading database ... 408637 files and directories currently installed.)
Preparing to unpack .../Nessus-10.12.4-debian10_amd64.deb ...
Unpacking nessus (10.12.4) over (10.12.4) ...
Setting up nessus (10.12.4) ...
```

Figure 3: Nessus package installation on Kali Linux

### 6.2 Starting and Verifying the Nessus Service

After installation, the Nessus service was started using the following command:

```
sudo systemctl start nessusd
```

The status of the Nessus service was then checked using:

```
sudo systemctl status nessusd
```

The service status confirmed that the Nessus daemon was running successfully.

```
C:\home\kali> sudo systemctl status nessusd.service
● nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/usr/lib/systemd/system/nessusd.service; disabled; preset: disabled)
   Active: active (running) since Thu 2026-10-01 01:46:52 EDT; 19s ago
     Invocation: f05afa79da7740d18f1e51c48129bd43
   Main PID: 10026 (nessus-service)
      Tasks: 14 (limit: 2199)
     Memory: 86.4M (peak: 86.4M)
        CPU: 16.675s
    CGroup: /system.slice/nessusd.service
            └─10026 /opt/nessus/sbin/nessus-service -q
              └─10027 nessusd -q

Oct 01 01:46:52 kali systemd[1]: Started nessusd.service - The Nessus Vulnerability Scanner.
Oct 01 01:46:52 kali nessus-service[10026]: nessus-service [10026][INFO] : Nessus 19.18.4 [build 20038] Started
```

Figure 4: Nessus service status verification

### 6.3 Nessus Web Interface

After starting the Nessus service, the Nessus web interface was accessed locally through HTTPS using port **8834**.

The Nessus web interface was accessed using:

```
https://127.0.0.1:8834
```

The web interface provided access to Nessus configuration, scan creation, vulnerability results, and plugin management.

```
C:\home\kali> sudo ss -lntp | grep 8834
LISTEN 1      1024      0.0.0.0:8834      0.0.0.0:*      users:(("nessusd",pid=10027,fd=18))
LISTEN 0      1024      [::]:8834        [::]:*        users:(("nessusd",pid=10027,fd=19))
```

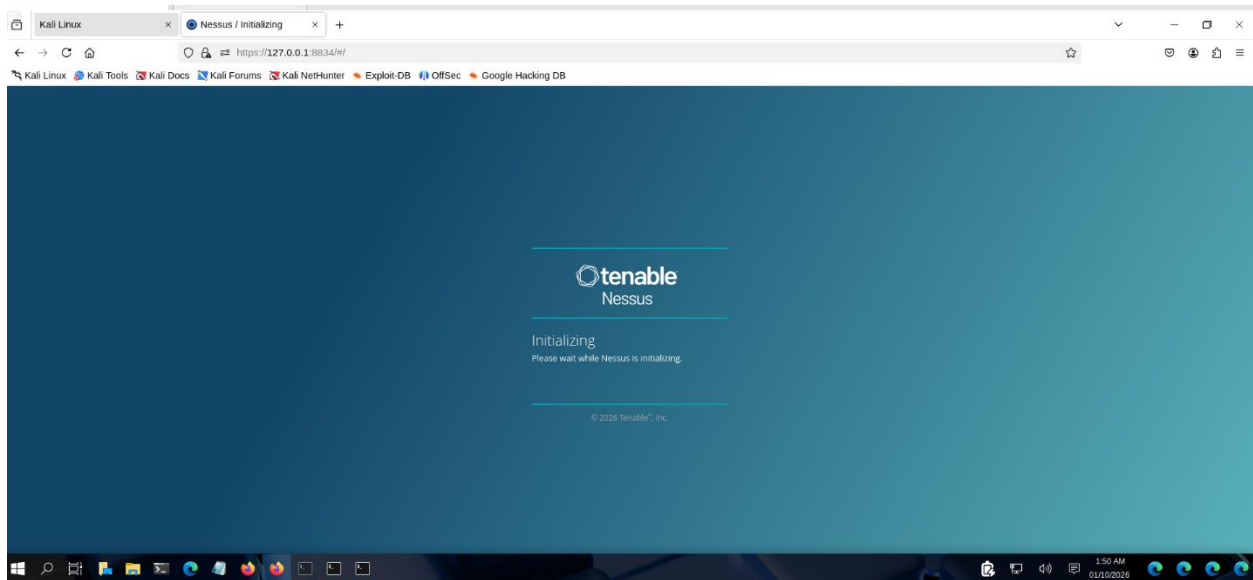
Figure 5: Nessus web interface accessed through port 8834

### 6.4 Verification of Nessus Listening Port

The Nessus web service was verified from the Kali Linux terminal. The following command was used to check whether Nessus was listening on TCP port 8834:

```
sudo ss -lntp | grep 8834
```

The command confirmed that the Nessus daemon was listening on TCP port **8834**.



*Figure 6: Nessus listening port verification*

## 6.5 Nessus Plugin Update

Before performing the vulnerability scan, the Nessus plugins were updated using:

```
sudo /opt/nessus/sbin/nessuscli update --plugins-only
```

The plugin update process was allowed to complete. Successful completion was indicated by the message:

Nessus Plugins: Complete

The updated plugins provided the vulnerability checks required for the subsequent vulnerability assessment.

```
File Actions Edit View Help
kali@kali:~$ sudo /opt/nessus/sbin/nessuscli update --plugins-only
Refreshing Nessus license information... complete; continuing with updates.
version: 3.1.2
build: 3.1.2
—— Fetching the newest updates from nessus.org ——
```



```
Nessus Plugins: Unpacking (0%)
Nessus Plugins: Unpacking (0%)
Nessus Plugins: Unpacking (0%) components...
Nessus Plugins: Unpacking (0%)
Nessus Plugins: Unpacking (0%)
Nessus Plugins: Unpacking (0%) by typing /bin/systemctl start nessusd.service
Nessus Plugins: Unpacking (0%) HOSTNAME_OR_IP:8834/ to configure your scanner
Nessus Plugins: Unpacking (0%)
Nessus Plugins: Unpacking (0%)
Nessus Plugins: Unpacking (0%) art nessusd.service
Nessus Plugins: Unpacking (0%)
[info] Copying templates version 202608131746 to /opt/nessus/var/nessus/templates/tmp
[info] Finished copying templates.
[info] Moved new templates with version 202608131746 from plugins dir.: (preset: disabled)
Nessus Plugins: Complete
Nessus Plugins: Complete since Thu 2026-10-01 01:00:55 CDT; 19s ago
Nessus Plugins: Complete
Nessus Plugins: Complete
* Nessus Plugins are now up-to-date and the changes will be automatically processed by Nessus.
```

*Figure 7: Nessus plugin update completion*

## 6.6 Installation and Configuration Result

The Nessus installation and configuration process was completed successfully. The Nessus service was started and verified, the web interface was accessed through HTTPS port 8834, and the Nessus plugins were updated successfully.

After successful installation and plugin updating, Nessus was ready to be configured for the vulnerability assessment of the authorized Metasploitable 2 target.

## 7. NESSUS SCAN CONFIGURATION

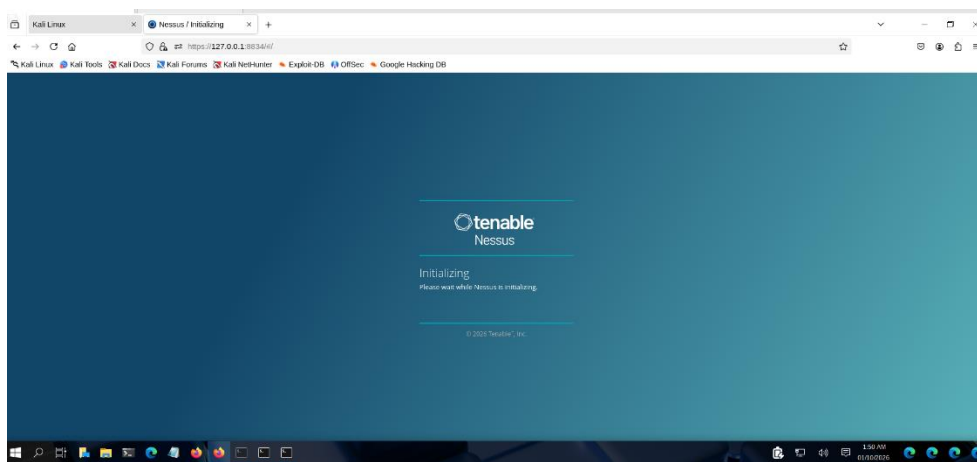
After successfully installing and updating Nessus, a vulnerability scan was configured for the authorized Metasploitable 2 target. The purpose of this step was to configure Nessus to assess the services and vulnerabilities present on the laboratory target.

### 7.1 Accessing the Nessus Dashboard

The Nessus web interface was opened from the Kali Linux system using the following local HTTPS address:

`https://127.0.0.1:8834`

After successful authentication, the Nessus dashboard was displayed.



*Figure 8: Nessus dashboard*

### 7.2 Creating a New Scan

From the Nessus dashboard, the **New Scan** option was selected to create a new vulnerability assessment.

#### Procedure

1. Open the Nessus dashboard.
2. Select **New Scan**.
3. Select the **Basic Network Scan** template.
4. Enter a suitable name for the scan.
5. Enter the authorized Metasploitable 2 IP address in the target field.

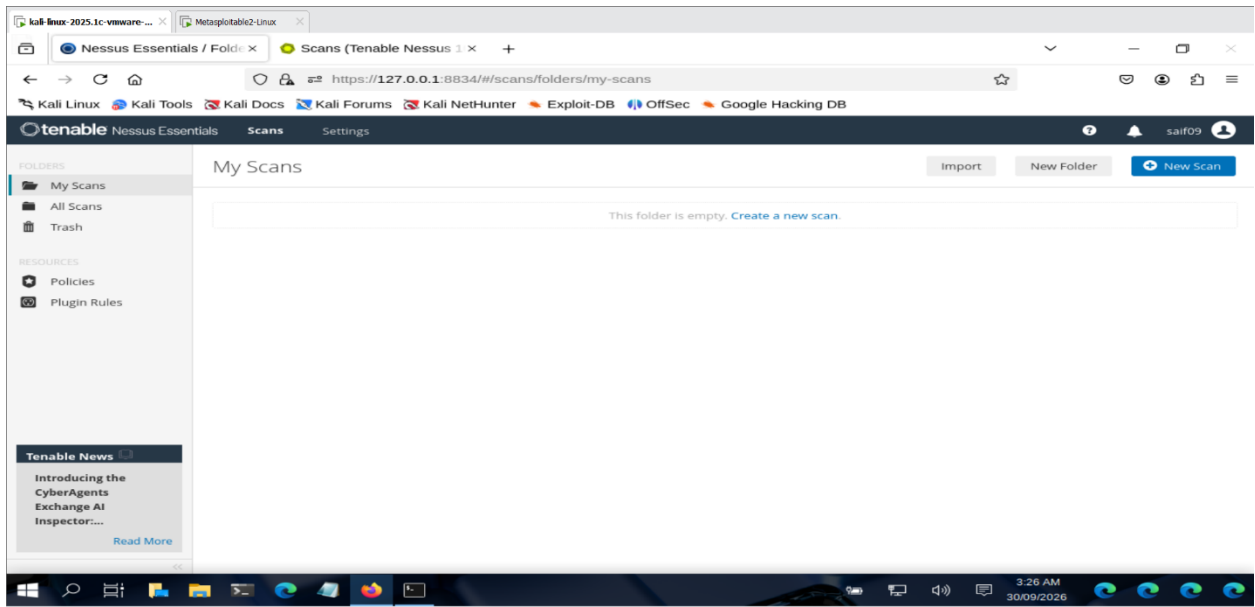


Figure 9: Creating a new Nessus vulnerability scan

### 7.3 Selecting the Scan Template

The **Basic Network Scan** template was selected because it provides a general-purpose vulnerability assessment of network-accessible services.

The scan configuration page was then opened to define the scan name and target.

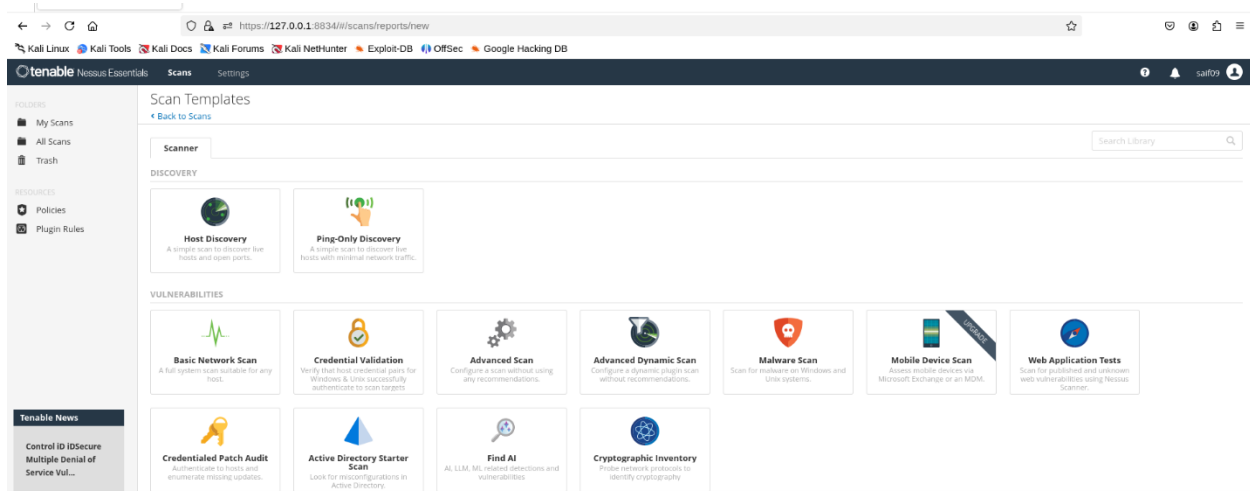


Figure 10: Basic Network Scan template configuration

### 7.4 Entering Scan Name

A descriptive name was assigned to the scan:

## Metasploitable 2 Vulnerability Assessment

The scan name was used to identify the assessment in the Nessus scan list.

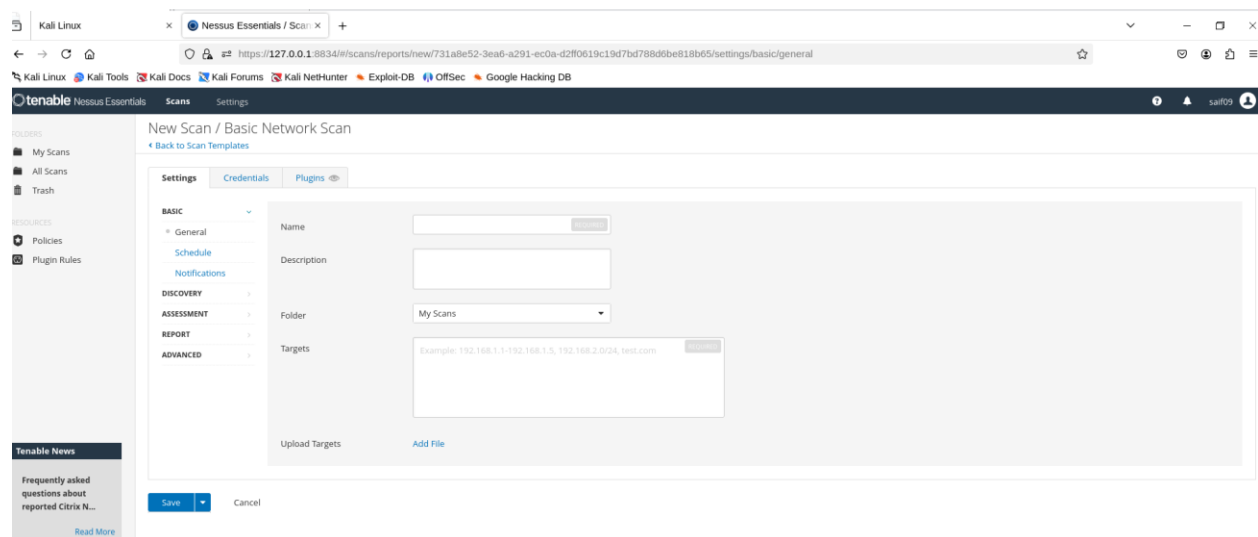


Figure 11: Nessus scan name configuration

## 7.5 Configuring the Target

The authorized Metasploitable 2 target IP address was entered in the **Targets** field:

192.168.52.129

Only the authorized laboratory target was included in the assessment.

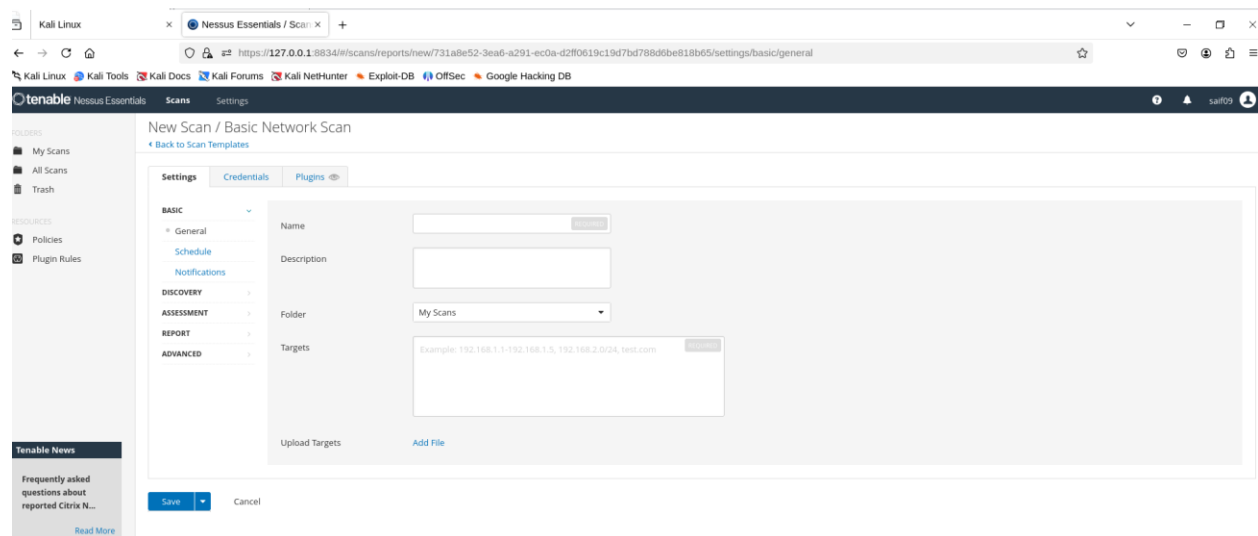


Figure 12: Metasploitable 2 target configuration

## 7.6 Saving the Scan

After reviewing the configuration, the scan was saved using the **Save** option. The configured scan then appeared in the Nessus scan list and was ready for execution.

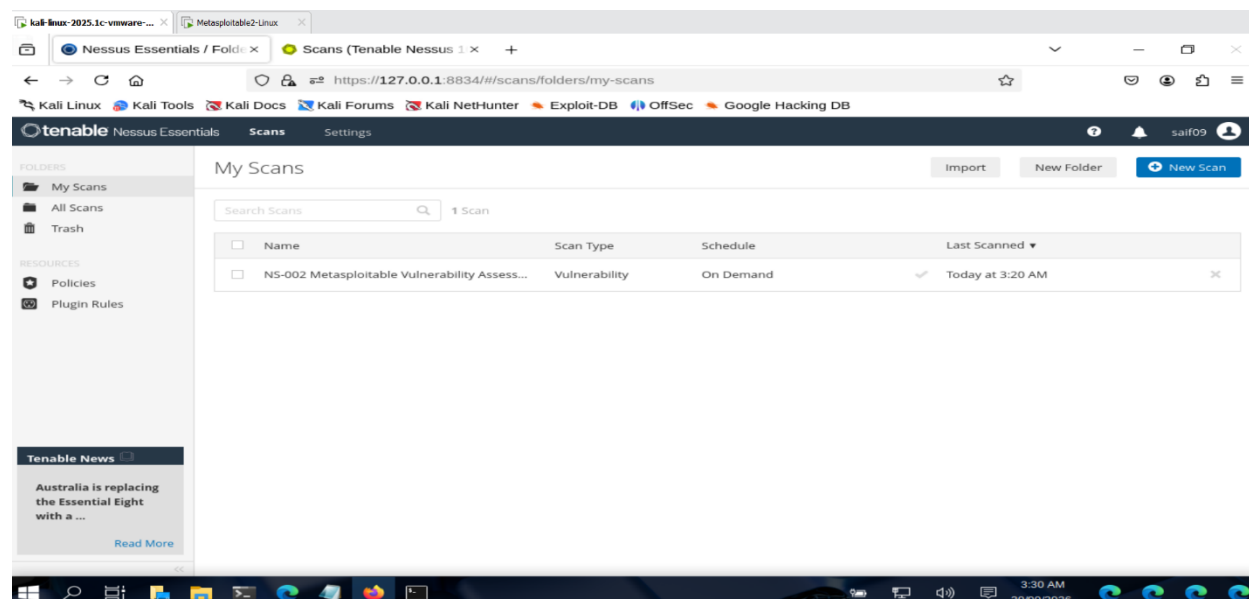


Figure 14: Saved Metasploitable 2 vulnerability scan

## 7.8 Result

The Nessus vulnerability scan was successfully configured for the authorized Metasploitable 2 target at **192.168.52.129**. The scan configuration included the Basic Network Scan template and the correct target IP address. The scan was saved successfully and prepared for execution.

The configured scan was used in the next stage to assess the exposed services and identify known vulnerabilities present on the Metasploitable 2 system.

## 8. NESSUS SCAN EXECUTION

After configuring the vulnerability scan, the scan was started against the authorized Metasploitable 2 target at IP address **192.168.52.129**.

### 8.1 Opening the Configured Scan

The saved **Metasploitable 2 Vulnerability Assessment** scan was opened from the Nessus scan list.

#### Procedure

1. Open the Nessus dashboard.
2. Navigate to the **Scans** section.
3. Locate the configured **Metasploitable 2 Vulnerability Assessment** scan.
4. Open the scan to review its configuration.
5. Verify that the target is **192.168.52.129**.

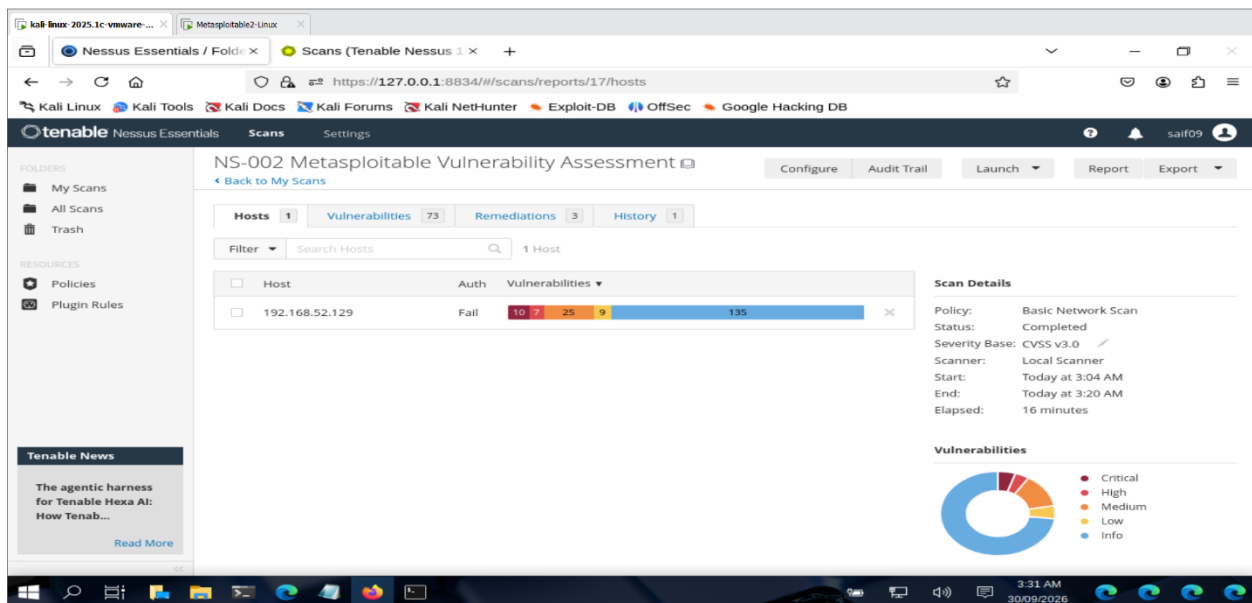


Figure 15: Configured Metasploitable 2 vulnerability scan

### 8.2 Starting the Vulnerability Scan

The configured scan was started using the **Launch** option.

Nessus then began performing automated security checks against the authorized Metasploitable 2 target.

## Procedure

1. Open the configured scan.
2. Verify the target IP address.
3. Select **Launch**.
4. Confirm that the scan status changes to **Running**.

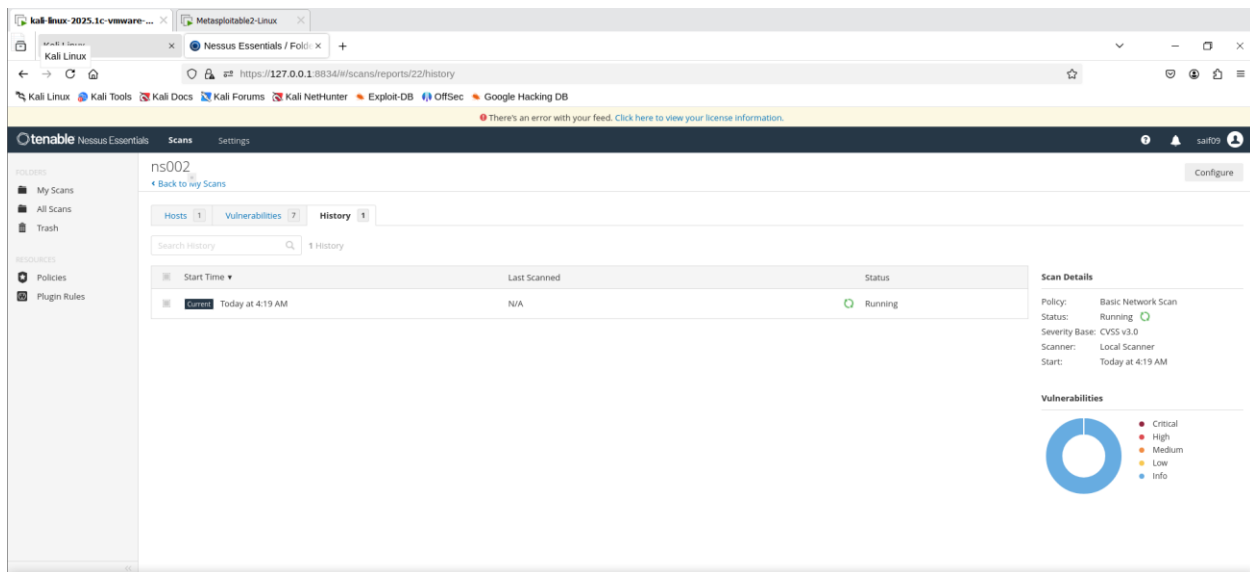


Figure 16: Nessus vulnerability scan in progress

## 8.3 Monitoring the Scan

While the scan was running, Nessus displayed the scan progress and status. The assessment was allowed to continue until the scan completed.

Nessus performed automated checks against the services and applications identified on the target system. The scan examined the target for known vulnerabilities, outdated software, insecure configurations, and other security weaknesses.

## 8.4 Scan Completion

The scan was allowed to complete before reviewing the vulnerability results. After completion, the scan status changed to **Completed** and the Nessus dashboard displayed the vulnerability summary categorized according to severity.

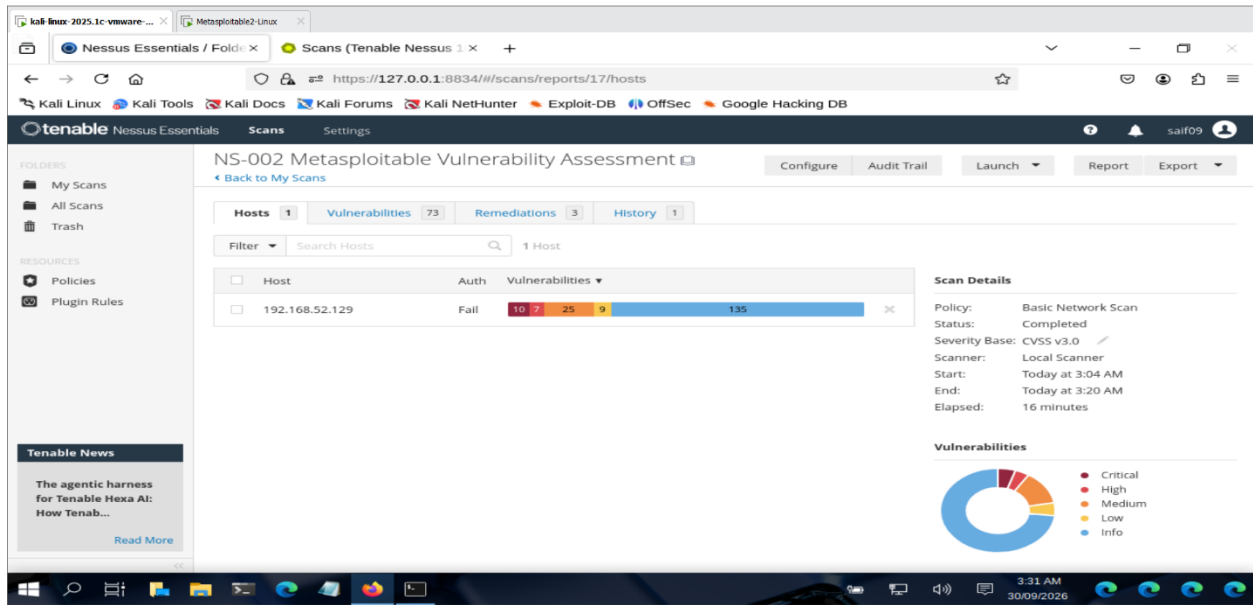


Figure 18: Completed Nessus vulnerability scan

## 8.5 Opening the Scan Results

After the scan completed successfully, the scan results were opened for detailed analysis.

The identified vulnerabilities were reviewed according to:

- Severity
- Vulnerability name
- Affected service
- CVE information, where available
- Nessus plugin information
- Evidence provided by Nessus



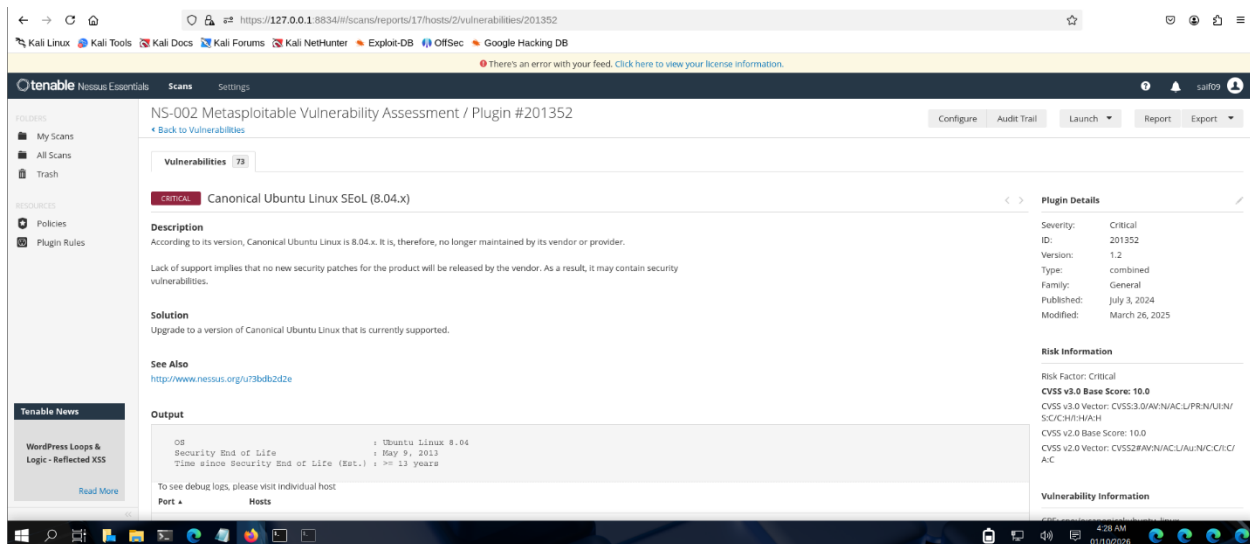


Figure 19: Nessus vulnerability scan results summary

## 8.6 Scan Execution Result

The Nessus vulnerability scan was successfully executed against the authorized Metasploitable 2 target at **192.168.52.129**. The scan completed successfully and generated vulnerability findings categorized by severity. These findings were subsequently reviewed and documented for further analysis and remediation.

## 9. VULNERABILITY FINDINGS

The completed Nessus vulnerability scan identified multiple security vulnerabilities and weaknesses on the authorized Metasploitable 2 target. A total of **12 vulnerability findings** were selected and documented for detailed analysis.

The findings were reviewed based on their vulnerability description, CVE reference where available, severity, CVSS score, affected service or port, and Nessus detection information.

### 9.1 Nessus Vulnerability Findings

The following table summarizes the 12 vulnerability findings identified during the Nessus assessment.

| S. No. | Vulnerability                                         | CVE                                         | Severity        | CVSS | Affected Service              |
|--------|-------------------------------------------------------|---------------------------------------------|-----------------|------|-------------------------------|
| 1      | Canonical Ubuntu Linux 8.04.x End of Life             | N/A                                         | <b>Critical</b> | 10.0 | OS / HTTP                     |
| 2      | ISC BIND Service Downgrade / Reflected DoS            | CVE-2020-8616                               | <b>High</b>     | 8.6  | DNS – 53                      |
| 3      | SSL Medium Strength Cipher Suites Supported (SWEET32) | CVE-2016-2183                               | <b>High</b>     | 7.5  | SMTP – 25 / PostgreSQL – 5432 |
| 4      | TLS Version 1.0 Protocol Detection                    | N/A                                         | <b>Medium</b>   | 6.5  | SMTP – 25 / PostgreSQL – 5432 |
| 5      | rsh Service Detection                                 | CVE-1999-0651                               | <b>High</b>     | 7.5  | rsh – 514                     |
| 6      | NFS Shares World Readable                             | N/A                                         | <b>High</b>     | 7.5  | NFS – 2049                    |
| 7      | Samba Badlock Vulnerability                           | CVE-2016-2118                               | <b>High</b>     | 7.5  | SMB – 445                     |
| 8      | SSL Anonymous Cipher Suites Supported                 | CVE-2007-1858                               | <b>Medium</b>   | 5.9  | SMTP – 25                     |
| 9      | SSL DROWN Attack Vulnerability                        | CVE-2016-0800                               | <b>Medium</b>   | 5.9  | SMTP – 25                     |
| 10     | HTTP TRACE / TRACK Methods Allowed                    | CVE-2003-1567, CVE-2004-2320, CVE-2010-0386 | <b>Medium</b>   | 5.3  | HTTP – 80                     |

| S. No. | Vulnerability                                                | CVE           | Severity | CVSS | Affected Service |
|--------|--------------------------------------------------------------|---------------|----------|------|------------------|
| 11     | SMB Signing Not Required                                     | N/A           | Medium   | 5.3  | SMB – 445        |
| 12     | SSL/TLS EXPORT_RSA ≤ 512-bit Cipher Suites Supported (FREAK) | CVE-2015-0204 | Medium   | 4.3  | SSL/TLS          |

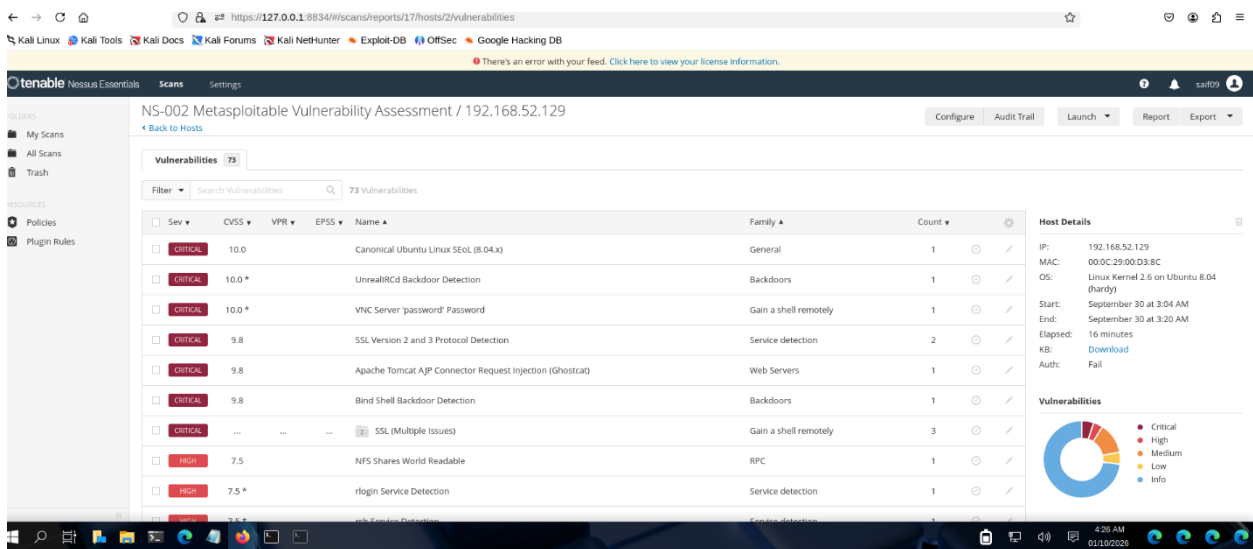


Figure 20: Nessus vulnerability findings and severity summary

## 9.2 Severity Distribution

The 12 selected vulnerability findings were distributed across the severity categories reported by Nessus as follows:

| Severity      | Number of Findings |
|---------------|--------------------|
| Critical      | 1                  |
| High          | 5                  |
| Medium        | 6                  |
| Low           | 0                  |
| Informational | 0                  |
| <b>Total</b>  | <b>12</b>          |

The assessment identified **1 Critical, 5 High, and 6 Medium** severity findings among the 12 documented vulnerabilities.

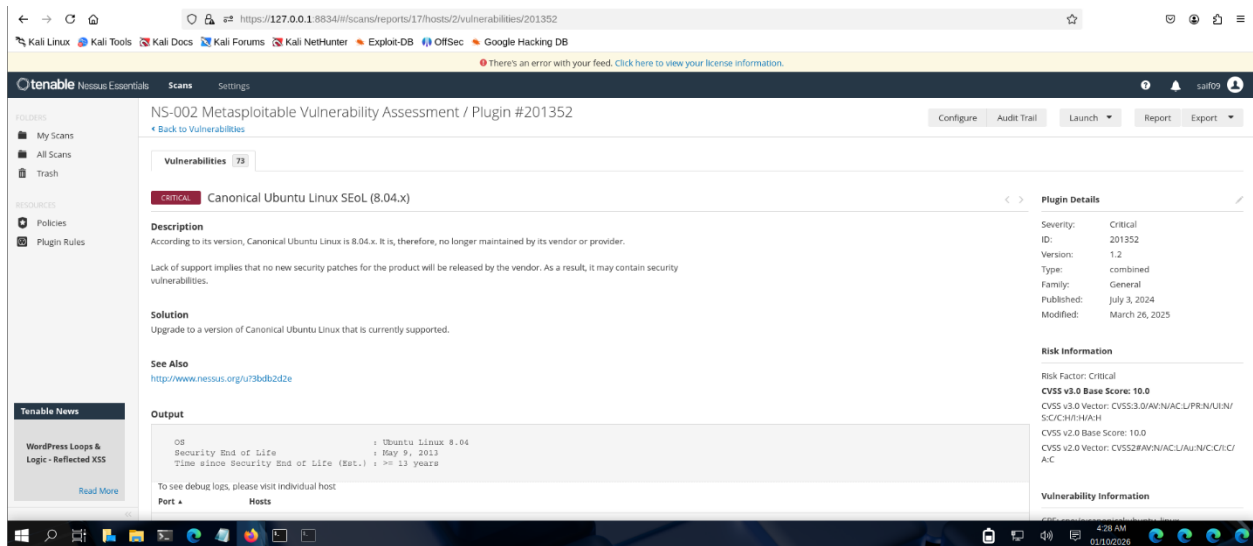


Figure 21: Nessus vulnerability severity distribution

## 9.3 Vulnerability Evidence

Each vulnerability finding was reviewed using the corresponding Nessus plugin details. The plugin information was used to identify the vulnerability description, affected service, severity, CVSS score, CVE reference where available, and technical evidence reported by Nessus.

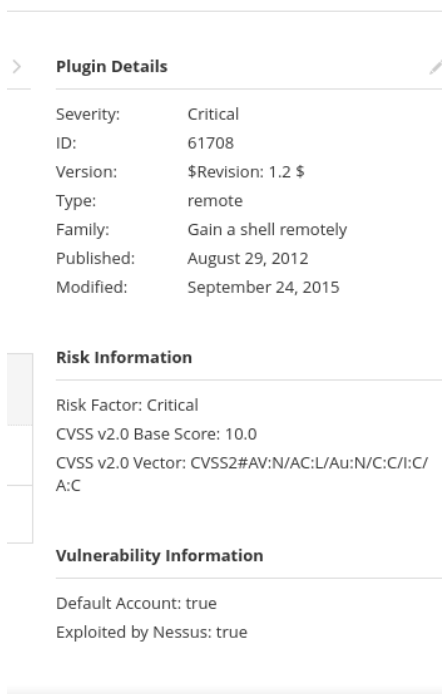


Figure 22: Nessus plugin details and vulnerability evidence

## 9.4 Vulnerability Analysis

The findings demonstrate that the Metasploitable 2 system contains several intentionally vulnerable or outdated components. The assessment identified weaknesses involving outdated operating-system software, DNS, SSL/TLS configurations, remote shell services, NFS permissions, SMB security, and HTTP configuration.

The findings were documented directly from the Nessus assessment results. The affected services and ports were compared with the services identified during the earlier Nmap discovery phase.

## 9.5 Findings Summary

The Nessus assessment successfully identified and documented 12 vulnerability findings on the authorized Metasploitable 2 target. The findings consisted of **1 Critical, 5 High, and 6 Medium** severity vulnerabilities.

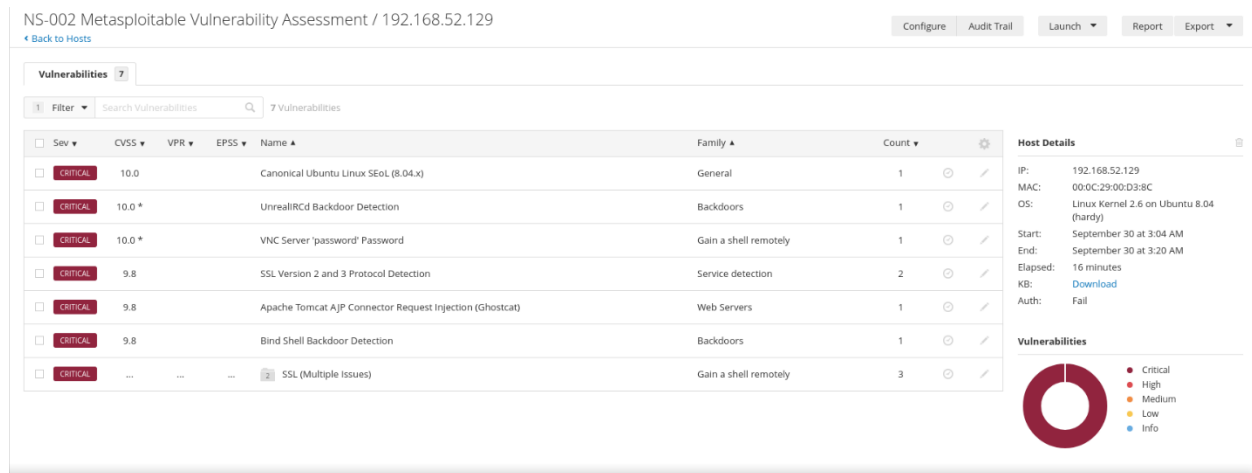
The vulnerability information obtained from Nessus was used for the subsequent vulnerability verification, impact analysis, and remediation recommendations presented in the following sections of this report.

## 10. DETAILED VULNERABILITY ANALYSIS

The following table presents the 12 vulnerabilities identified during the Nessus vulnerability assessment of the Metasploitable 2 target. The vulnerability names, CVE identifiers, severity levels, CVSS scores, and affected services are based on the completed Nessus scan.

| S. No. | Vulnerability                                               | CVE                                         | Severity | CVSS | Affected Service          |
|--------|-------------------------------------------------------------|---------------------------------------------|----------|------|---------------------------|
| 1      | Canonical Ubuntu Linux 8.04.x End of Life                   | N/A                                         | Critical | 10.0 | OS / HTTP                 |
| 2      | ISC BIND Service Downgrade / Reflected DoS                  | CVE-2020-8616                               | High     | 8.6  | DNS 53                    |
| 3      | SSL Medium Strength Cipher Suites Supported (SWEET32)       | CVE-2016-2183                               | High     | 7.5  | SMTP 25 / PostgreSQL 5432 |
| 4      | TLS Version 1.0 Protocol Detection                          | N/A                                         | Medium   | 6.5  | SMTP 25 / PostgreSQL 5432 |
| 5      | rsh Service Detection                                       | CVE-1999-0651                               | High     | 7.5  | rsh 514                   |
| 6      | NFS Shares World Readable                                   | N/A                                         | High     | 7.5  | NFS 2049                  |
| 7      | Samba Badlock Vulnerability                                 | CVE-2016-2118                               | High     | 7.5  | SMB 445                   |
| 8      | SSL Anonymous Cipher Suites Supported                       | CVE-2007-1858                               | Medium   | 5.9  | SMTP 25                   |
| 9      | SSL DROWN Attack Vulnerability                              | CVE-2016-0800                               | Medium   | 5.9  | SMTP 25                   |
| 10     | HTTP TRACE / TRACK Methods Allowed                          | CVE-2003-1567, CVE-2004-2320, CVE-2010-0386 | Medium   | 5.3  | HTTP 80                   |
| 11     | SMB Signing Not Required                                    | N/A                                         | Medium   | 5.3  | SMB 445                   |
| 12     | SSL/TLS EXPORT_RSA ≤512-bit Cipher Suites Supported (FREAK) | CVE-2015-0204                               | Medium   | 4.3  | SSL/TLS                   |

The findings demonstrate that the target system contains outdated operating-system components, legacy network services, weak cryptographic configurations, insecure protocols, and exposed file-sharing services.



*Figure 9: Nessus detailed vulnerability findings*

The screenshot above should show the Nessus vulnerability results containing the identified findings and their corresponding severity levels. The screenshot serves as evidence that the vulnerabilities were identified during the completed Nessus assessment.

Each finding should be reviewed using the corresponding Nessus plugin details and technical evidence before remediation is recommended. The assessment results should be correlated with the services identified during the Nmap service and version discovery phase to understand which exposed services are associated with the reported vulnerabilities.

## 10.1 Canonical Ubuntu Linux 8.04.x End of Life

**Severity:** Critical

**CVSS Score:** 10.0

**CVE:** N/A

**Affected Service:** OS / HTTP

### Description

The Nessus scan identified that the target system is running Canonical Ubuntu Linux 8.04.x, which has reached its end of life. An end-of-life operating system no longer receives normal security updates and vendor-supported security fixes.

### Risk

The absence of regular security updates increases the possibility that known vulnerabilities remain unpatched. Attackers may exploit vulnerabilities in outdated operating-system components or associated services.

### Evidence

Nessus reported **Canonical Ubuntu Linux 8.04.x End of Life** with a **Critical severity** and a **CVSS score of 10.0**. The finding was associated with the target operating system and HTTP-related components.

**Affected Service**

**Operating System / HTTP**

**Recommendation**

Upgrade the operating system to a currently supported Ubuntu release. Apply all available security updates and maintain a regular patch-management process. Unsupported operating systems should not be used for production systems.

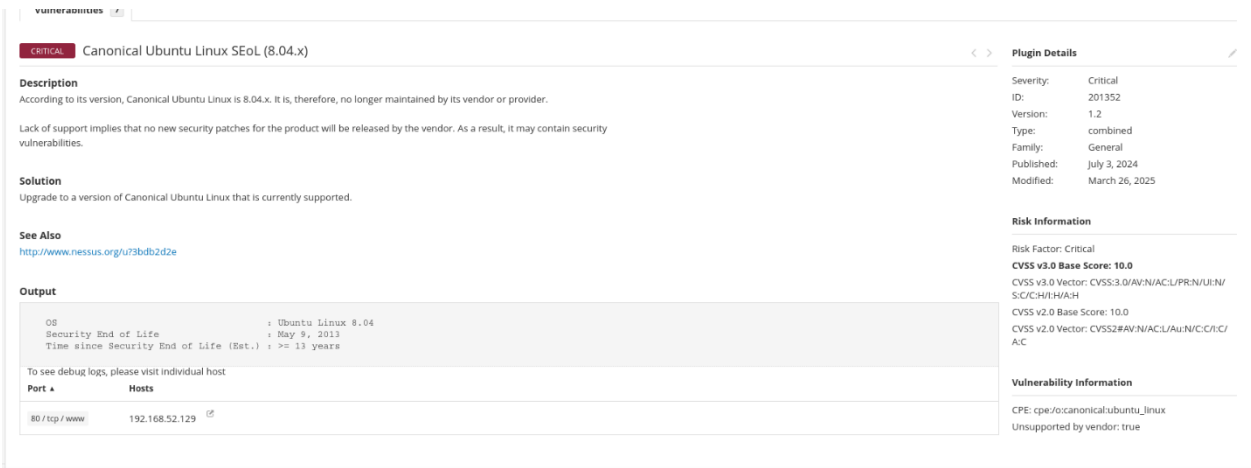


Figure 10: Nessus details for Canonical Ubuntu Linux 8.04.x End of Life

**10.2 ISC BIND Service Downgrade / Reflected DoS**

**Severity:** High

**CVSS Score:** 8.6

**CVE:** CVE-2020-8616

**Affected Service:** DNS – Port 53

**Description**

Nessus identified a vulnerability associated with the ISC BIND DNS service. The finding relates to a service downgrade/reflected denial-of-service condition affecting vulnerable BIND configurations or versions.

**Risk**

A vulnerable DNS service may be abused to cause service disruption or contribute to denial-of-service activity. DNS availability is important because systems often depend on DNS for hostname resolution.

**Evidence**



Nessus reported **ISC BIND Service Downgrade / Reflected DoS** with **High severity**, a **CVSS score of 8.6**, and **CVE-2020-8616**. The affected service is DNS on port 53.

**Affected Service**

**DNS – Port 53**

**Recommendation**

Upgrade ISC BIND to a supported and patched version. Disable unnecessary DNS functionality, restrict access to trusted systems where appropriate, and regularly update DNS server software.

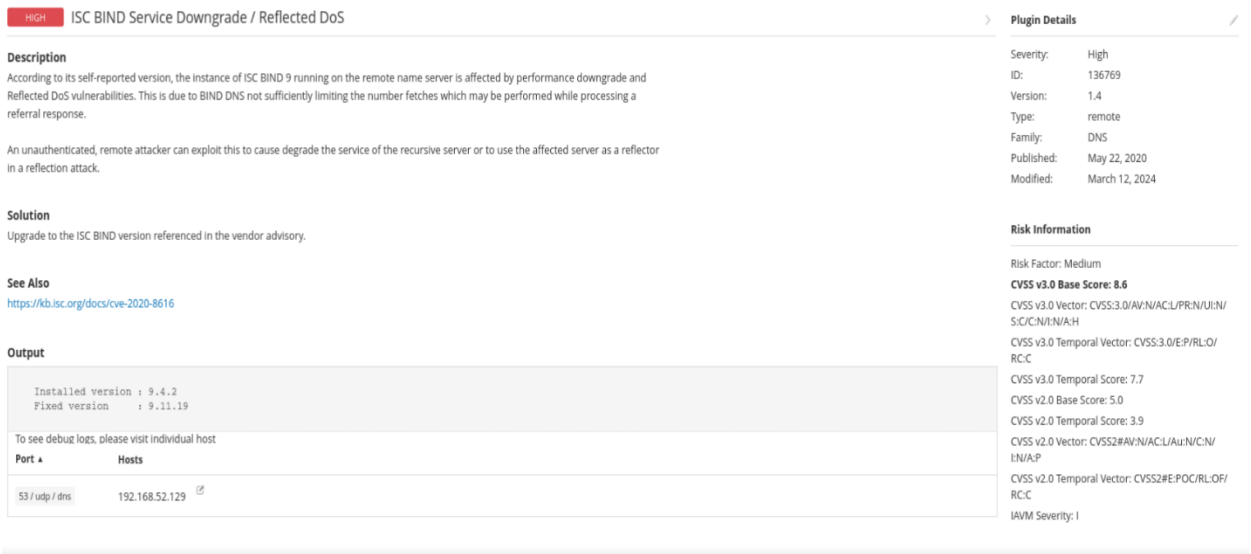


Figure 11: Nessus details for ISC BIND Service Downgrade / Reflected DoS

**10.3 SSL Medium Strength Cipher Suites Supported (SWEET32)**

**Severity:** High

**CVSS Score:** 7.5

**CVE:** CVE-2016-2183

**Affected Service:** SMTP – Port 25 / PostgreSQL – Port 5432

**Description**

The Nessus scan detected support for medium-strength SSL/TLS cipher suites associated with the SWEET32 vulnerability. SWEET32 is related to the use of 64-bit block ciphers that can become vulnerable when a sufficiently large amount of encrypted traffic is collected.

**Risk**

Weak or medium-strength cryptographic configurations can reduce the security of encrypted communications. Under suitable conditions, an attacker may be able to recover information from encrypted traffic.

**Evidence**

Nessus reported **SSL Medium Strength Cipher Suites Supported (SWEET32)** with **High severity**, **CVSS 7.5**, and **CVE-2016-2183**. The affected services identified in the scan were SMTP on port 25 and PostgreSQL on port 5432.

Affected Service

SMTP – Port 25 / PostgreSQL – Port 5432

Recommendation

Disable weak and medium-strength cipher suites, particularly legacy 64-bit block ciphers, and configure modern cryptographic algorithms and protocols. Keep SSL/TLS libraries and affected services updated.

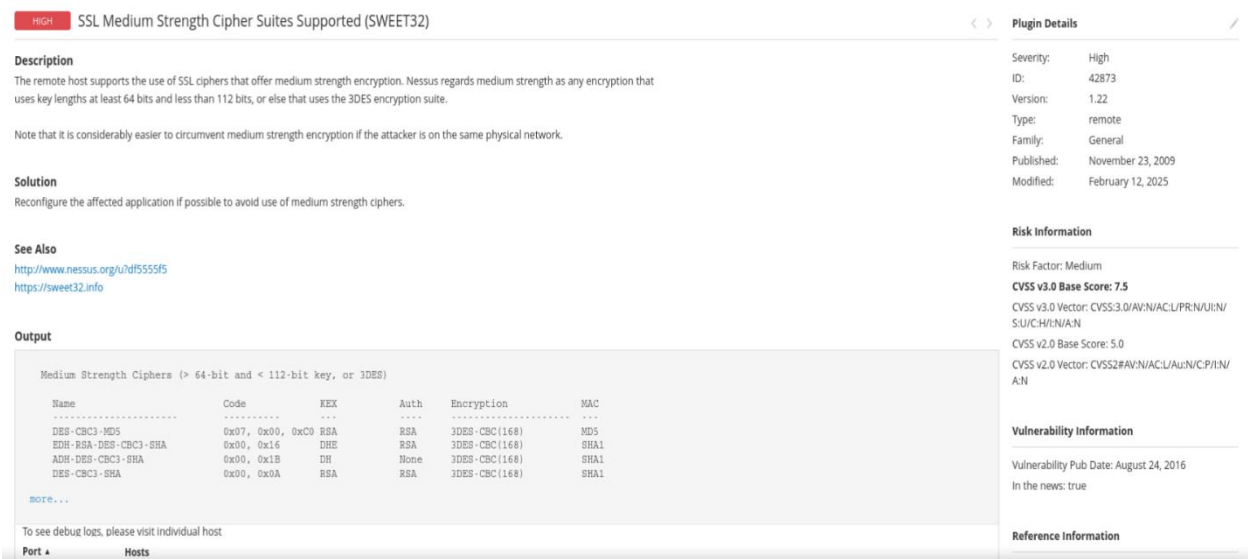


Figure 12: Nessus details for SSL Medium Strength Cipher Suites Supported (SWEET32)

10.4 TLS Version 1.0 Protocol Detection

Severity: Medium

CVSS Score: 6.5

CVE: N/A

Affected Service: SMTP – Port 25 / PostgreSQL – Port 5432

Description

Nessus detected support for the legacy TLS 1.0 protocol. TLS 1.0 is an outdated protocol version and does not provide the security level expected from modern TLS configurations.

Risk

Allowing obsolete TLS versions can increase the attack surface and may permit weaker cryptographic negotiation. It can also create compatibility and compliance issues when stronger protocol versions are required.

## Evidence

Nessus reported **TLS Version 1.0 Protocol Detection** with **Medium severity** and a **CVSS score of 6.5**. The finding was associated with SMTP port 25 and PostgreSQL port 5432.

## Affected Service

**SMTP – Port 25 / PostgreSQL – Port 5432**

## Recommendation

Disable TLS 1.0 and configure the affected services to use modern TLS versions supported by the application and environment. Review the complete SSL/TLS configuration and remove

**MEDIUM** TLS Version 1.0 Protocol Detection

**Description**  
The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

**Solution**  
Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

**See Also**  
<https://tools.ietf.org/html/draft-ietf-tls-oldversions-deprecate-00>

**Output**

| Port                    | Hosts          |
|-------------------------|----------------|
| 5432 / tcp / postgresql | 192.168.52.129 |

**Plugin Details**

Severity: Medium  
ID: 104743  
Version: 1.11  
Type: remote  
Family: Service detection  
Published: November 22, 2017  
Modified: April 13, 2026

**Risk Information**

Risk Factor: Medium  
**CVSS v3.0 Base Score: 6.5**  
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/L:IA:N  
CVSS v2.0 Base Score: 6.1  
CVSS v2.0 Vector: CVSS2#AV:N/AC:H/Au:N/C:C/I:P/A:N

**Vulnerability Information**

Asset Inventory: True

**Reference Information**

CWE: 327

Figure 13: Nessus details for TLS Version 1.0 Protocol Detection

## 10.5 rsh Service Detection

**Severity:** High

**CVSS Score:** 7.5

**CVE:** CVE-1999-0651

**Affected Service:** rsh – Port 514

## Description

The Nessus assessment detected the legacy Remote Shell (rsh) service. rsh is an insecure remote-access protocol because it does not provide the protections expected from modern secure remote administration protocols.

## Risk

Use of insecure remote-access services can expose authentication information and administrative sessions to interception or misuse. An exposed rsh service can therefore increase the risk of unauthorized remote access.

## Evidence

Nessus reported **rsh Service Detection** with **High severity**, **CVSS 7.5**, and **CVE-1999-0651**. The affected service was identified on TCP port 514.

## Affected Service

### rsh – Port 514

## Recommendation

Disable and remove the rsh service if it is not required. Replace legacy remote administration protocols with secure alternatives such as SSH. Restrict administrative services to trusted networks.

**HIGH** rsh Service Detection

**Description**  
The rsh service is running on the remote host. This service is vulnerable since data is passed between the rsh client and server in cleartext. A man-in-the-middle attacker can exploit this to sniff logins and passwords. Also, it may allow poorly authenticated logins without passwords. If the host is vulnerable to TCP sequence number guessing (from any network) or IP spoofing (including ARP hijacking on a local network) then it may be possible to bypass authentication. Finally, rsh is an easy way to turn file-write access into full logins through the .rhosts or rhosts.equiv files.

**Solution**  
Comment out the 'rsh' line in /etc/inetd.conf and restart the inetd process. Alternatively, disable this service and use SSH instead.

**Output**  
No output recorded.  
To see debug logs, please visit individual host

| Port        | Hosts          |
|-------------|----------------|
| 514/tcp/rsh | 192.168.52.129 |

**Plugin Details**

Severity: High  
ID: 10245  
Version: 1.38  
Type: remote  
Family: Service detection  
Published: August 22, 1999  
Modified: April 11, 2022

**Risk Information**

Risk Factor: High  
CVSS v2.0 Base Score: 7.5  
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P

**Vulnerability Information**

Exploit Available: true  
Exploit Ease: Exploits are available  
Vulnerability Pub Date: January 1, 1990

**Exploitable With**  
Metasploit (rlogin Authentication Scanner)

Figure 14: Nessus details for rsh Service Detection

## 10.6 NFS Shares World Readable

**Severity:** High

**CVSS Score:** 7.5

**CVE:** N/A

**Affected Service:** NFS – Port 2049

## Description

Nessus identified NFS shares that are configured to allow world-readable access. This means that files or directories exported through NFS may be readable by unauthorized users depending on the share configuration and network access.

## Risk

Improperly configured NFS shares may expose sensitive files and information. An attacker who can access the NFS service may be able to retrieve data that should be restricted.

## Evidence

Nessus reported **NFS Shares World Readable** with **High severity** and a **CVSS score of 7.5**. The affected service was NFS on port 2049.

## Affected Service

### NFS – Port 2049

## Recommendation

Review all NFS exports and restrict access to only authorized hosts and networks. Apply appropriate file permissions and avoid exporting sensitive directories unnecessarily. Disable unused NFS exports.

The screenshot displays the Nessus interface for a vulnerability titled "NFS Shares World Readable". The severity is marked as "HIGH". The description states: "The remote NFS server is exporting one or more shares without restricting access (based on hostname, IP, or IP range)." The solution advises: "Place the appropriate restrictions on all NFS shares." A "See Also" link points to <http://www.tldp.org/HOWTO/NFS-HOWTO/security.html>. The output section shows a list of shares with no access restrictions, specifically mentioning "/ \*". Below this, a table lists the port and hosts affected:

| Port                 | Hosts          |
|----------------------|----------------|
| 2049 / tcp / rpc-nfs | 192.168.52.129 |

On the right side, the "Plugin Details" section provides metadata: Severity: High, ID: 42256, Version: 1.12, Type: remote, Family: RPC, Published: October 26, 2009, Modified: February 21, 2024. The "Risk Information" section shows a Risk Factor of Medium and a CVSS v3.0 Base Score of 7.5, along with CVSS vectors. The "Vulnerability Information" section at the bottom notes the publication date as January 1, 1985.

Figure 15: Nessus details for NFS Shares World Readable

## 10.7 Samba Badlock Vulnerability

**Severity:** High

**CVSS Score:** 7.5

**CVE:** CVE-2016-2118

**Affected Service:** SMB – Port 445

## Description

The Nessus scan identified a Samba vulnerability associated with the Badlock security issue. The finding affects vulnerable Samba implementations and indicates that the SMB service requires security updates or configuration review.

## Risk

A vulnerable Samba service may expose the system to attacks against SMB-related functionality. Because SMB services can provide access to shared resources, exploitation could have a significant security impact.

Evidence

Nessus reported **Samba Badlock Vulnerability** with **High severity**, **CVSS 7.5**, and **CVE-2016-2118**. The affected SMB service was identified on port 445.

Affected Service

SMB – Port 445

Recommendation

Upgrade Samba to a supported and patched version. Review SMB configuration, restrict SMB access to trusted networks, and disable unnecessary SMB services.

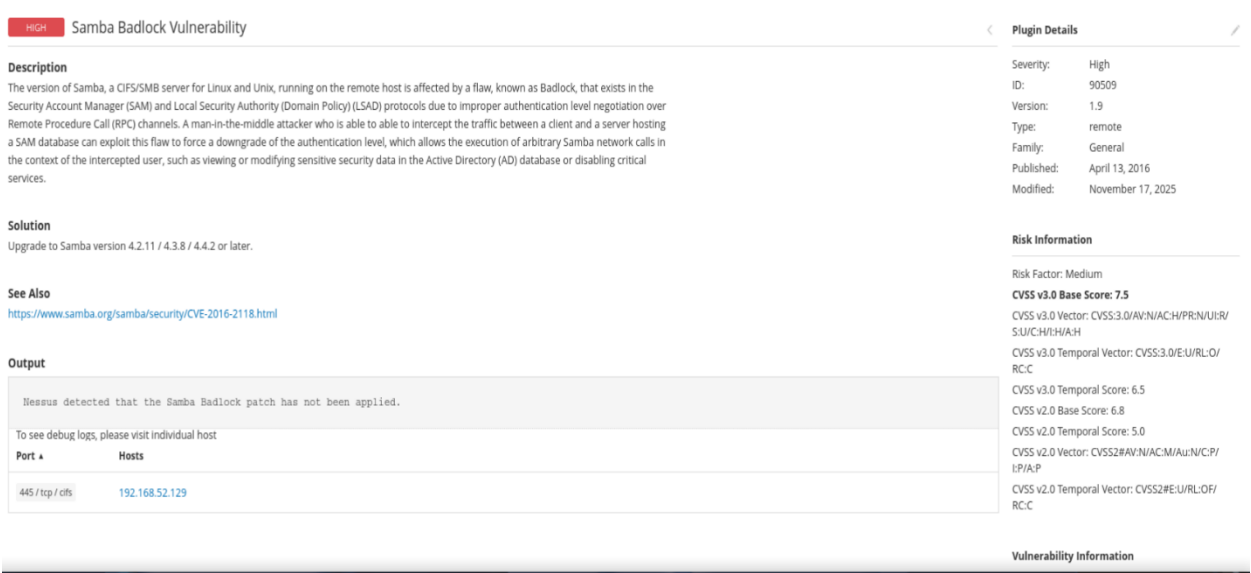


Figure 16: Nessus details for Samba Badlock Vulnerability

10.8 SSL Anonymous Cipher Suites Supported

Severity: Medium

CVSS Score: 5.9

CVE: CVE-2007-1858

Affected Service: SMTP – Port 25

Description

Nessus detected support for anonymous SSL cipher suites on the SMTP service. Anonymous cipher suites do not provide normal authentication of the communicating endpoint.

Risk

The absence of proper authentication can make it more difficult to establish trust in the remote endpoint and may increase exposure to man-in-the-middle attacks depending on the overall configuration.

## Evidence

Nessus reported **SSL Anonymous Cipher Suites Supported** with **Medium** severity, **CVSS 5.9**, and **CVE-2007-1858**. The affected service was SMTP on port 25.

## Affected Service

### SMTP – Port 25

## Recommendation

Disable anonymous cipher suites and configure the SMTP service to use authenticated and appropriately secured TLS configurations. Review the complete list of supported cipher suites.

**MEDIUM** SSL Anonymous Cipher Suites Supported

**Description**  
The remote host supports the use of anonymous SSL ciphers. While this enables an administrator to set up a service that encrypts traffic without having to generate and configure SSL certificates, it offers no way to verify the remote host's identity and renders the service vulnerable to a man-in-the-middle attack.

Note: This is considerably easier to exploit if the attacker is on the same physical network.

**Solution**  
Reconfigure the affected application if possible to avoid use of weak ciphers.

**See Also**  
<http://www.nessus.org/u?3a040ada>

**Output**

The following is a list of SSL anonymous ciphers supported by the remote TCP server :

Low Strength Ciphers (<= 64-bit key)

| Name                | Code       | KEY | Auth | Encryption  | MAC         |
|---------------------|------------|-----|------|-------------|-------------|
| EXP-ADH-DES-CBC-SHA | 0x00, 0x19 | DE  | None | DES-CBC(40) | SHA1 export |
| EXP-ADH-RC4-SHA     | 0x00, 0x17 | DE  | None | RC4(40)     | MD5 export  |
| EXP-ADH-RC4-SHA     | 0x00, 0x17 | DE  | None | RC4(40)     | MD5 export  |

NOTE...

To see debug logs, please visit individual host

Port 25 Hosts

**Plugin Details**

Severity: Medium  
ID: 31705  
Version: 1.31  
Type: remote  
Family: Service detection  
Published: March 28, 2008  
Modified: October 27, 2023

**Risk Information**

Risk Factor: Low  
CVSS v3.0 Base Score: 5.9  
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N  
CVSS v3.0 Temporal Vector: CVSS:3.0/E:U/R:L/O:/RC:C  
CVSS v3.0 Temporal Score: 5.2  
CVSS v2.0 Base Score: 2.6  
CVSS v2.0 Temporal Score: 1.9  
CVSS v2.0 Vector: CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N  
CVSS v2.0 Temporal Vector: CVSS2#E:U/R:L/O:/RC:C

**Vulnerability Information**

Figure 17: Nessus details for SSL Anonymous Cipher Suites Supported

## 10.9 SSL DROWN Attack Vulnerability

**Severity:** Medium

**CVSS Score:** 5.9

**CVE:** CVE-2016-0800

**Affected Service:** SMTP – Port 25

## Description

Nessus identified an SSL/TLS configuration associated with the DROWN vulnerability. DROWN is related to the use of vulnerable SSLv2 configurations that can weaken the security of encrypted communications.

## Risk

A vulnerable SSL/TLS configuration may allow an attacker to obtain information about encrypted communications under specific conditions. Continued support for legacy SSL protocols increases the cryptographic attack surface.

## Evidence

Nessus reported **SSL DROWN Attack Vulnerability** with **Medium severity**, **CVSS 5.9**, and **CVE-2016-0800**. The affected service identified by Nessus was SMTP on port 25.

## Affected Service

### SMTP – Port 25

## Recommendation

Disable SSLv2 and other obsolete protocols. Configure the SMTP service to use modern TLS versions and secure cipher suites. Keep the underlying SSL/TLS implementation updated.

**Medium** SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)

**Description**  
The remote host supports SSLv2 and therefore may be affected by a vulnerability that allows a cross-protocol Bleichenbacher padding oracle attack known as DROWN (Decrypting RSA with Obsolete and Weakened eNcryption). This vulnerability exists due to a flaw in the Secure Sockets Layer Version 2 (SSLv2) implementation, and it allows captured TLS traffic to be decrypted. A man-in-the-middle attacker can exploit this to decrypt the TLS connection by utilizing previously captured traffic and weak cryptography along with a series of specially crafted connections to an SSLv2 server that uses the same private key.

**Solution**  
Disable SSLv2 and export grade cryptography cipher suites. Ensure that private keys are not used anywhere with server software that supports SSLv2 connections.

**See Also**  
<https://drownattack.com/>  
<https://drownattack.com/drown-attack-paper.pdf>

**Output**  
The remote host is affected by SSL DROWN and supports the following vulnerable cipher suites :

Low Strength Ciphers (<= 64-bit key)

| Name            | Code             | KEY | Auth | Encryption  | MAC |
|-----------------|------------------|-----|------|-------------|-----|
| EXP-RS2-CBC-MD5 | 0x04, 0x00, 0x80 | RSA | RSA  | RC2-CBC(40) | MD5 |
| EXP-RS2-CBC-MD5 | 0x04, 0x00, 0x80 | MD5 | MD5  | RC2-CBC(40) | MD5 |

**Plugin Details**  
Severity: Medium  
ID: 89058  
Version: 1.15  
Type: remote  
Family: Misc.  
Published: March 1, 2016  
Modified: April 13, 2026

**Risk Information**  
Risk Factor: Medium  
**CVSS v3.0 Base Score: 5.9**  
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N  
CVSS v3.0 Temporal Vector: CVSS:3.0/E:U/RL:O/R:C  
CVSS v3.0 Temporal Score: 5.2  
CVSS v2.0 Base Score: 4.3  
CVSS v2.0 Temporal Score: 3.2  
CVSS v2.0 Vector: CVSS2#AV:N/AC:M/Au:N/C:P/I:N/A:N  
CVSS v2.0 Temporal Vector: CVSS2#E:U/RL:O/R:C

**Vulnerability Information**

Figure 18: Nessus details for SSL DROWN Attack Vulnerability

## 10.10 HTTP TRACE / TRACK Methods Allowed

**Severity:** Medium

**CVSS Score:** 5.3

**CVE:** CVE-2003-1567, CVE-2004-2320, CVE-2010-0386

**Affected Service:** HTTP – Port 80

## Description

Nessus detected that the HTTP service allows TRACE and/or TRACK methods. These HTTP methods can expose request information and are generally unnecessary for normal web-server operation.

## Risk

Permitting unnecessary HTTP methods can increase the attack surface of a web server. Under certain application configurations, HTTP TRACE-related behavior may contribute to cross-site tracing or information-disclosure scenarios.



## Evidence

Nessus reported **HTTP TRACE / TRACK Methods Allowed** with **Medium severity**, **CVSS 5.3**, and the associated CVEs **CVE-2003-1567**, **CVE-2004-2320**, and **CVE-2010-0386**. The affected HTTP service was identified on port 80.

## Affected Service

### HTTP – Port 80

## Recommendation

Disable HTTP TRACE and TRACK methods when they are not required. Review the web-server configuration and allow only the HTTP methods required by the application.

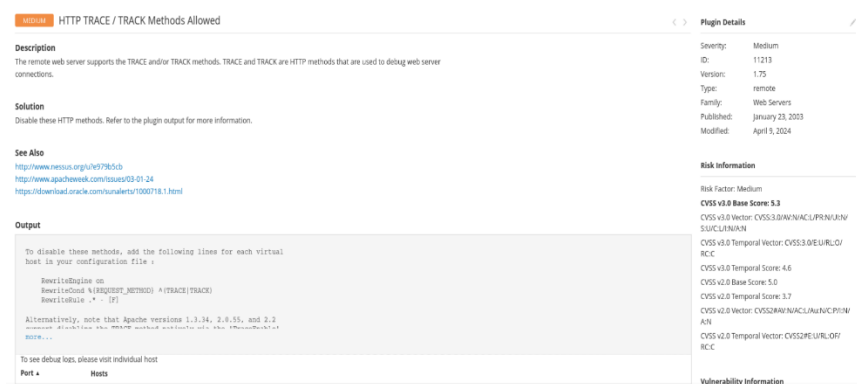


Figure 19: Nessus details for HTTP TRACE / TRACK Methods Allowed

## 10.11 SMB Signing Not Required

**Severity:** Medium

**CVSS Score:** 5.3

**CVE:** N/A

**Affected Service:** SMB – Port 445

## Description

Nessus identified that SMB signing is not required on the target system. SMB signing provides a mechanism for protecting the integrity and authenticity of SMB communications.

## Risk

When SMB signing is not required, an attacker positioned appropriately on the network may have increased opportunity to interfere with SMB communications. This can increase exposure to relay and man-in-the-middle attack scenarios.

## Evidence

Nessus reported **SMB Signing Not Required** with **Medium severity** and a **CVSS score of 5.3**. The affected SMB service was identified on port 445.

## Affected Service

### SMB – Port 445

## Recommendation

Configure the SMB server to require signing where appropriate. Review SMB security policies and restrict SMB access to trusted networks. Apply secure Samba configuration practices.

MEDIUM

SMB Signing not required

Description

Signing is not required on the remote SMB server. An unauthenticated, remote attacker can exploit this to conduct man-in-the-middle attacks against the SMB server.

Solution

Enforce message signing in the host's configuration. On Windows, this is found in the policy setting 'Microsoft network server: Digitally sign communications (always)'. On Samba, the setting is called 'server signing'. See the 'see also' links for further details.

See Also

<http://www.nessus.org/u/df39b8b3>  
<http://technet.microsoft.com/en-us/library/cc731957.aspx>  
<http://www.nessus.org/u/74b80723>  
<http://www.samba.org/samba/docs/current/man-html/smb.conf.5.html>  
<http://www.nessus.org/u/a3cac4ea>

Output

No output recorded.

To see debug logs, please visit individual host

| Port             | Hosts          |
|------------------|----------------|
| 445 / tcp / cifs | 192.168.52.129 |

Plugin Details

Severity: Medium

ID: 57608

Version: 1.20

Type: remote

Family: Misc.

Published: January 19, 2012

Modified: October 5, 2022

Risk Information

Risk Factor: Medium

CVSS v3.0 Base Score: 5.3

CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

CVSS v3.0 Temporal Vector: CVSS:3.0/E:U/RL:O/RCC

CVSS v3.0 Temporal Score: 4.6

CVSS v2.0 Base Score: 5.0

CVSS v2.0 Temporal Score: 3.7

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:N/I:P/A:N

CVSS v2.0 Temporal Vector: CVSS2#E:U/RL:O/RCC

Vulnerability Information

Figure 20: Nessus details for SMB Signing Not Required

## 10.12 SSL/TLS EXPORT\_RSA ≤512-bit Cipher Suites Supported (FREAK)

**Severity:** Medium

**CVSS Score:** 4.3

**CVE:** CVE-2015-0204

**Affected Service:** SSL/TLS

## Description

Nessus detected support for legacy EXPORT\_RSA cipher suites using RSA keys of 512 bits or less. This configuration is associated with the FREAK vulnerability and represents an obsolete cryptographic configuration.

## Risk

Weak export-grade cryptography can reduce the strength of encrypted communications. If vulnerable configurations are exposed, attackers may be able to take advantage of weak cryptographic parameters under suitable conditions.

## Evidence

Nessus reported **SSL/TLS EXPORT\_RSA ≤512-bit Cipher Suites Supported (FREAK)** with **Medium severity**, **CVSS 4.3**, and **CVE-2015-0204**.

Affected Service

SSL/TLS

Recommendation

Disable EXPORT\_RSA and other obsolete or weak cipher suites. Configure modern cryptographic algorithms and secure TLS versions. Regularly review SSL/TLS configurations for deprecated cryptographic options.

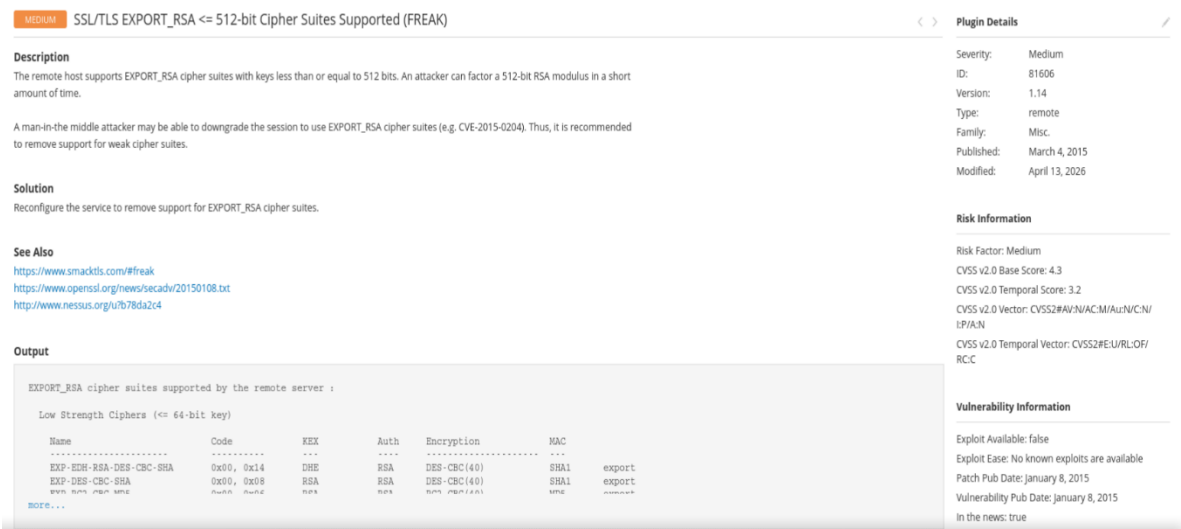


Figure 21: Nessus details for SSL/TLS EXPORT\_RSA ≤512-bit Cipher Suites Supported (FREAK)

10.13 Overall Vulnerability Analysis

The Nessus assessment identified vulnerabilities across multiple security areas of the Metasploitable 2 system. The findings include an end-of-life operating system, vulnerable DNS and SMB services, insecure legacy remote-access protocols, exposed NFS resources, and outdated SSL/TLS configurations.

The assessment identified **1 Critical, 5 High, and 6 Medium severity vulnerabilities**, resulting in a total of **12 documented findings**. The results demonstrate the security risks associated with outdated software, unnecessary network services, weak cryptographic configurations, and insufficient access controls.

The vulnerability analysis also provides a basis for the remediation phase. Each finding should be addressed according to its affected service, severity, exposure, and operational requirement. After remediation, the system should be rescanned to verify that the identified vulnerabilities have been resolved or appropriately mitigated.

## 11. FINDING VERIFICATION

The important Nessus findings were reviewed against the information obtained during the initial Nmap service and version discovery. This comparison was performed to determine whether the services associated with the reported vulnerabilities were actually exposed on the authorized Metasploitable 2 target.

The Nmap service and version scan identified multiple open services that corresponded with services reported by Nessus. These included DNS, HTTP, SMB, NFS, SMTP, PostgreSQL, and other network services.

### 11.1 Verification Methodology

The verification process consisted of the following activities:

- Comparing Nessus-reported services with the Nmap service and version discovery results.
- Checking the affected port and service associated with each Nessus finding.
- Reviewing the corresponding Nessus plugin description and detection evidence.
- Confirming that the reported service was reachable on the authorized Metasploitable 2 target.
- Correlating the Nessus findings with the service information obtained during Nmap scanning.
- Avoiding destructive exploitation during the verification process.

### 11.2 Nessus and Nmap Correlation

The following table summarizes the correlation between selected Nessus findings and the services identified during the Nmap scan.

| Nessus Finding                                        | Affected Service  | Port      | Nmap Verification                     |
|-------------------------------------------------------|-------------------|-----------|---------------------------------------|
| ISC BIND Service Downgrade / Reflected DoS            | DNS               | 53        | ISC BIND 9.4.2 detected               |
| SSL Medium Strength Cipher Suites Supported (SWEET32) | SMTP / PostgreSQL | 25 / 5432 | Postfix SMTP and PostgreSQL detected  |
| TLS Version 1.0 Protocol Detection                    | SMTP / PostgreSQL | 25 / 5432 | SMTP and PostgreSQL services detected |
| rsh Service Detection                                 | rsh               | 514       | TCP port 514 detected                 |

| <b>Nessus Finding</b>                 | <b>Affected Service</b> | <b>Port</b> | <b>Nmap Verification</b>     |
|---------------------------------------|-------------------------|-------------|------------------------------|
| NFS Shares World Readable             | NFS                     | 2049        | NFS service detected         |
| Samba Badlock Vulnerability           | SMB                     | 445         | Samba SMB service detected   |
| SSL Anonymous Cipher Suites Supported | SMTP                    | 25          | SMTP service detected        |
| SSL DROWN Attack Vulnerability        | SMTP                    | 25          | SMTP service detected        |
| HTTP TRACE / TRACK Methods Allowed    | HTTP                    | 80          | Apache HTTP service detected |
| SMB Signing Not Required              | SMB                     | 445         | Samba SMB service detected   |

The Nmap scan also identified additional exposed services, including FTP, SSH, Telnet, RPC, NetBIOS, MySQL, VNC, IRC, AJP13, and Apache Tomcat. These results demonstrate that the Metasploitable 2 system exposes a large number of network services.

### **11.3 Verification Result**

The comparison showed that the services associated with the important Nessus findings were present in the Nmap service and version discovery results. For example, Nmap identified **ISC BIND 9.4.2 on port 53, Apache HTTP on port 80, SMB/Samba on port 445, NFS on port 2049, Postfix SMTP on port 25, and PostgreSQL on port 5432.**

This correlation provides supporting evidence that the Nessus findings were associated with services actually exposed by the target system. However, service discovery alone does not independently prove exploitability; the Nessus plugin detection and configuration evidence were also reviewed as part of the assessment.

```

C:\home\kali> nmap -sV 192.168.52.129 -oN nmap-initial.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-01 01:23 EDT
Nmap scan report for 192.168.52.129
Host is up (0.0048s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:00:D3:8C (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.79 seconds

```

*Figure 22: Verification of Nessus findings using Nmap service and version information*

The screenshot should show the actual Nmap service and version discovery output containing the relevant ports and services used for correlation with the Nessus findings.

## 11.4 Conclusion

The verification process increased confidence in the vulnerability assessment by correlating automated Nessus findings with independently observed network services. Combining vulnerability scanning, service discovery, and manual review provides a more reliable assessment than relying solely on automated scanner results.

## 12. RISK ANALYSIS

The vulnerabilities identified during the Nessus assessment were analyzed according to their severity, affected services, potential security impact, and exposure on the target system.

The assessment identified a total of **12 vulnerabilities**, consisting of **1 Critical, 5 High, and 6 Medium severity findings**. No Low or Informational findings were included in the documented results. The presence of multiple outdated services and insecure configurations increases the overall attack surface of the laboratory system.

Critical and High severity findings require greater attention because they may have significant security consequences if similar weaknesses are present in a real production environment. Medium severity findings may also contribute to overall risk, particularly when combined with other vulnerabilities or insecure configurations.

### 12.1 Major Risk Areas

The major risk areas identified during the assessment include:

- **Outdated operating-system components and software:** The target uses legacy software and an end-of-life operating system.
- **Insecure legacy network protocols and services:** Services such as rsh and other legacy protocols increase the exposure of the system.
- **Weak or outdated cryptographic configurations:** The assessment identified issues involving legacy TLS versions, weak cipher suites, anonymous cipher suites, DROWN, SWEET32, and FREAK-related configurations.
- **Exposed file-sharing and remote-access services:** Services such as SMB, NFS, and legacy remote-access services increase the available attack surface.
- **Insecure SMB configuration:** SMB-related findings included the Samba Badlock vulnerability and SMB signing not being required.
- **Potentially unnecessary network services:** The Nmap assessment identified numerous network services exposed on the target system.
- **Lack of modern security controls:** Several findings demonstrate the risks associated with legacy services and outdated security configurations.

### 12.2 Severity Distribution

The documented Nessus findings were distributed as follows:

| Severity | Number of Findings |
|----------|--------------------|
| Critical | 1                  |

| Severity      | Number of Findings |
|---------------|--------------------|
| High          | 5                  |
| Medium        | 6                  |
| Low           | 0                  |
| Informational | 0                  |
| <b>Total</b>  | <b>12</b>          |

The severity distribution demonstrates that the majority of the documented findings were classified as High or Medium severity, while one finding was classified as Critical.

### 12.3 Laboratory Environment Consideration

Because Metasploitable 2 is intentionally designed as a vulnerable training platform, the presence of multiple security weaknesses is expected within this controlled laboratory environment. Therefore, the findings should be interpreted as part of cybersecurity learning, vulnerability assessment, and security-testing practice.

The results should not be interpreted as a production-system risk assessment. In a real environment, risk would additionally depend on factors such as asset importance, network exposure, business impact, existing security controls, likelihood of exploitation, and the sensitivity of affected information.

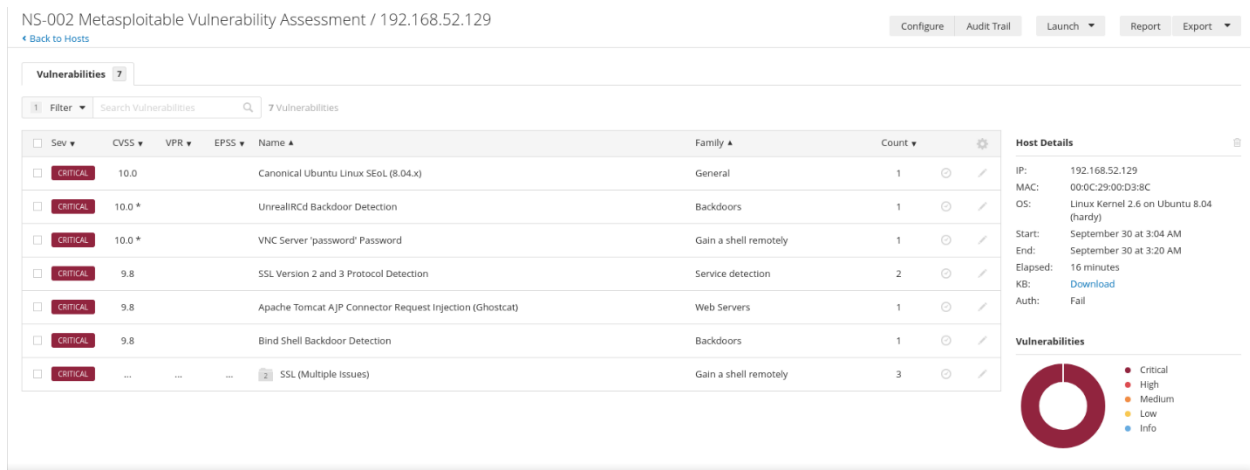


Figure 23(a): Nessus Critical severity vulnerability



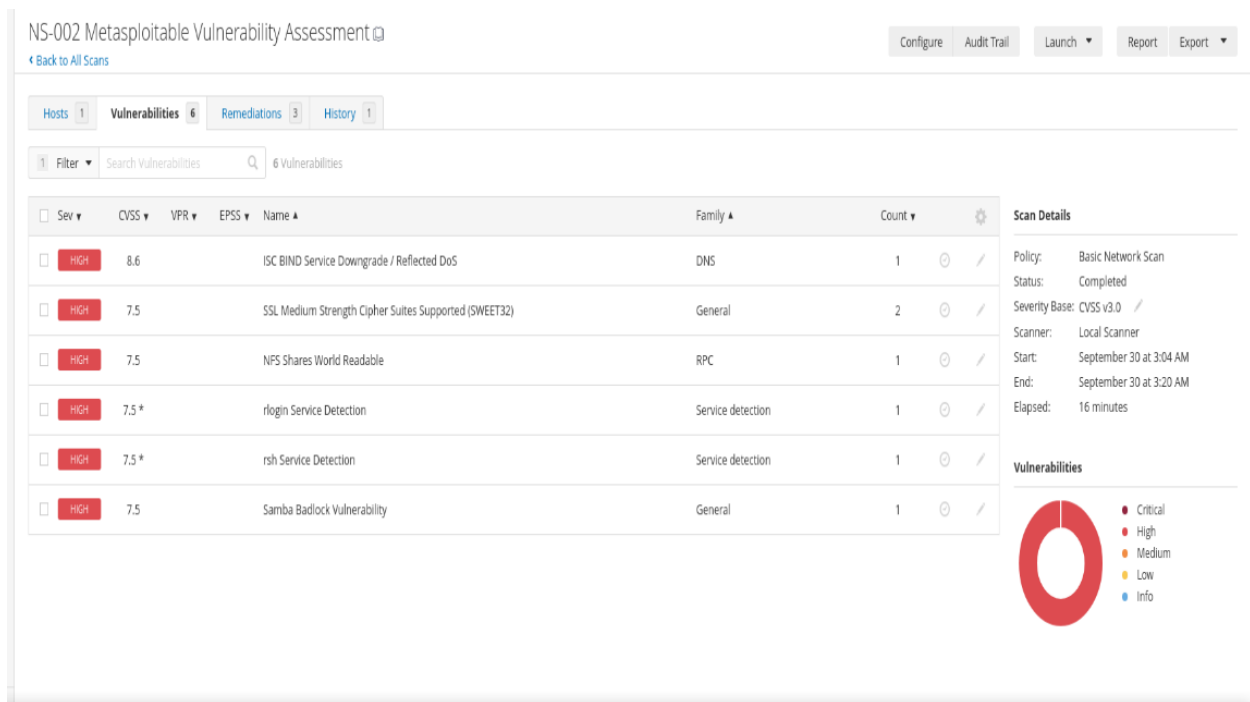


Figure 23(b): Nessus High severity vulnerabilities

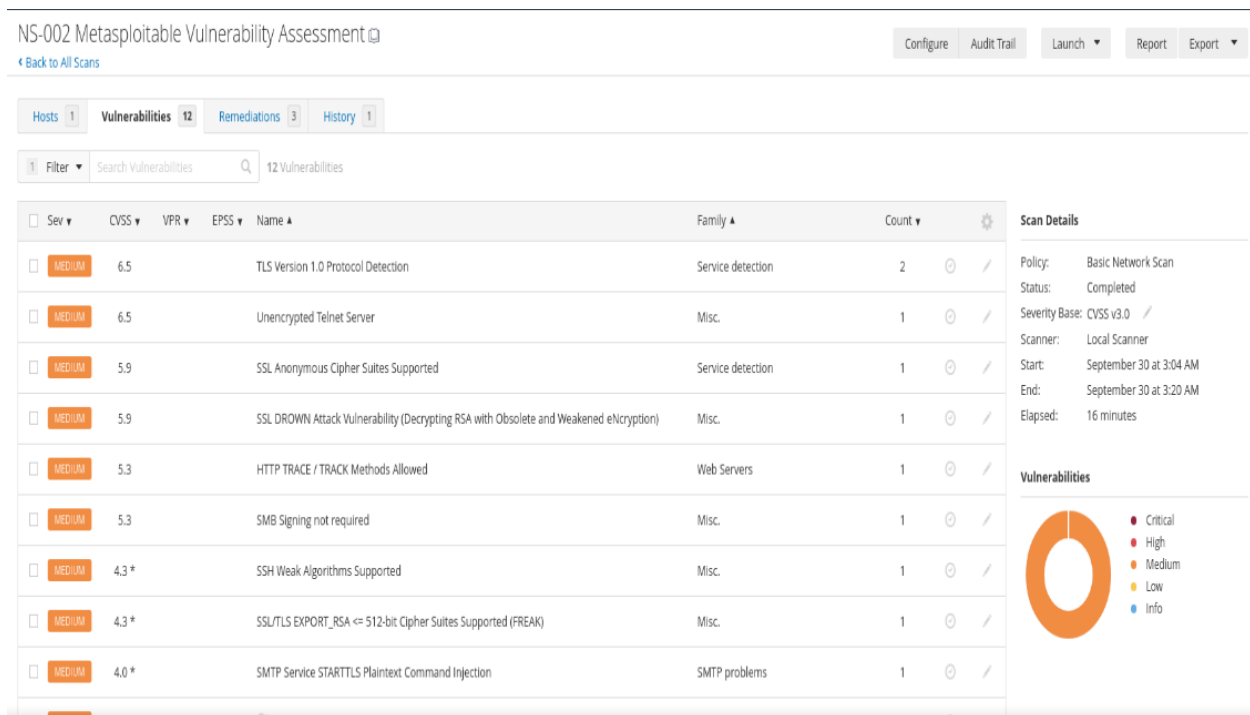


Figure 23(c): Nessus Medium severity vulnerabilities

The screenshot should show the Nessus vulnerability results or severity summary displaying the identified Critical, High, and Medium findings.

## 13. REMEDIATION RECOMMENDATIONS

Based on the vulnerabilities identified during the Nessus assessment, the following remediation measures are recommended to reduce the security exposure of the Metasploitable 2 laboratory system. The recommendations are based on the identified vulnerabilities, affected services, and security configurations observed during the assessment.

### 13.1 Patch and Update the Operating System

The end-of-life Ubuntu operating system should be upgraded to a currently supported release. Security updates and patches should be applied regularly to address known vulnerabilities and reduce exposure to publicly known security weaknesses.

**Related Finding:** Canonical Ubuntu Linux 8.04.x End of Life.

### 13.2 Disable Unnecessary Services

Network services that are not required should be disabled and removed where possible. Firewall rules should also be used to restrict access to services that must remain available.

**Related Services:** FTP, Telnet, rsh, SMB, NFS, database services, and other exposed services.

### 13.3 Secure Legacy Protocols

Legacy and insecure protocols such as Telnet and rsh should be disabled and replaced with secure alternatives. SSH should be used for secure remote administration where remote access is required.

**Related Finding:** rsh Service Detection.

### 13.4 Improve SMB Security

The Samba/SMB configuration should be updated and hardened. SMB signing should be enabled where appropriate, unnecessary SMB access should be restricted, and vulnerable Samba versions should be upgraded.

**Related Findings:** Samba Badlock Vulnerability and SMB Signing Not Required.

### 13.5 Secure NFS Configuration

NFS exports should be reviewed and restricted to authorized hosts and networks. Sensitive directories should not be unnecessarily exported, and file permissions should be configured according to the principle of least privilege.

**Related Finding:** NFS Shares World Readable.

### 13.6 Strengthen TLS Configuration

Weak, outdated, anonymous, and export-grade cryptographic configurations should be disabled. TLS 1.0 and obsolete cipher suites should be removed where they are not required. Modern TLS versions and secure cipher suites should be configured.

**Related Findings:**

- SSL Medium Strength Cipher Suites Supported (SWEET32)
- TLS Version 1.0 Protocol Detection
- SSL Anonymous Cipher Suites Supported
- SSL DROWN Attack Vulnerability
- SSL/TLS EXPORT\_RSA ≤512-bit Cipher Suites Supported (FREAK)

**13.7 Secure DNS Services**

The BIND DNS service should be upgraded to a supported version and configured securely. Unnecessary DNS functionality should be disabled, and access should be restricted to authorized systems where appropriate.

**Related Finding:** ISC BIND Service Downgrade / Reflected DoS.

**13.8 Secure Web Services**

The Apache HTTP service should be updated and securely configured. Unnecessary HTTP methods such as TRACE and TRACK should be disabled where they are not required.

**Related Finding:** HTTP TRACE / TRACK Methods Allowed.

**13.9 Restrict Network Services**

Exposed services such as DNS, SMTP, HTTP, SMB, NFS, PostgreSQL, MySQL, and other network services should be accessible only to systems and users that require them. Firewall rules and access-control mechanisms should be used to minimize unnecessary network exposure.

**13.10 Perform Regular Vulnerability Assessments**

Vulnerability scans should be performed periodically and after significant configuration or software changes. A follow-up Nessus scan should be conducted after remediation to verify that the identified vulnerabilities have been resolved or appropriately mitigated.

**13.11 Apply Network Segmentation**

Sensitive services should be placed on appropriate network segments. Firewall rules, access-control lists, and network segmentation should be used to limit communication between systems and reduce the impact of a potential compromise.

**13.12 Apply the Principle of Least Privilege**

Users, services, file shares, and network resources should be provided only with the permissions required for their intended functions. Excessive permissions should be removed to reduce unauthorized access and information-disclosure risks.

---

> **Plugin Details** 

---

Severity: Critical  
ID: 61708  
Version: \$Revision: 1.2 \$  
Type: remote  
Family: Gain a shell remotely  
Published: August 29, 2012  
Modified: September 24, 2015

**Risk Information**

---

Risk Factor: Critical  
CVSS v2.0 Base Score: 10.0  
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

**Vulnerability Information**

---

Default Account: true  
Exploited by Nessus: true

---

**Figure 24: Nessus vulnerability details used for remediation analysis**

The screenshot should show an actual Nessus vulnerability/plugin detail page containing the vulnerability description, affected service, severity, and available remediation or solution information. The screenshot provides supporting evidence for the remediation recommendations documented in this section.

## 14. KEY LEARNINGS

The Week 3 vulnerability assessment practical provided hands-on experience in identifying, analyzing, verifying, and documenting security weaknesses within an intentionally vulnerable laboratory environment.

The key learnings from this practical are:

- Understanding the **vulnerability assessment lifecycle**, from target discovery and scanning to analysis, verification, and remediation.
- Performing **service and version discovery using Nmap** to identify exposed network services and their versions.
- Installing and configuring **Tenable Nessus on Kali Linux**.
- Starting and verifying the Nessus service and accessing the Nessus web interface.
- Updating Nessus plugins before performing a vulnerability assessment.
- Configuring and executing a vulnerability scan against an **authorized laboratory target**.
- Understanding vulnerability **severity levels, CVE identifiers, and CVSS scores**.
- Analyzing vulnerable services, network ports, and associated security weaknesses.
- Collecting and documenting technical evidence from Nessus vulnerability results.
- Correlating Nessus findings with **Nmap service and version discovery results**.
- Understanding the importance of manually verifying automated scanner findings.
- Identifying security risks caused by **outdated software, legacy protocols, weak cryptographic configurations, and insecure services**.
- Developing appropriate **remediation recommendations** based on identified vulnerabilities.
- Understanding the importance of service hardening, patch management, access control, and network segmentation.
- Preparing professional vulnerability assessment documentation containing findings, evidence, analysis, and recommendations.

### 14.1 Practical Skills Developed

Through this practical, I developed practical skills in:

1. **Network reconnaissance** using Nmap.
2. **Vulnerability scanning** using Nessus.
3. **Vulnerability classification** using severity and CVSS information.

4. **CVE-based vulnerability identification.**
5. **Evidence collection and documentation.**
6. **Finding verification and service correlation.**
7. **Risk analysis and prioritization.**
8. **Security remediation planning.**
9. **Professional cybersecurity report preparation.**

Overall, this practical improved my understanding of vulnerability assessment, network service discovery, automated security scanning, risk analysis, evidence collection, finding verification, and basic vulnerability management. It also demonstrated the importance of combining automated security tools with manual analysis when evaluating the security posture of a system.

## 15. CONCLUSION

The Week 3 Vulnerability Assessment practical successfully demonstrated the process of identifying, analyzing, verifying, and documenting security vulnerabilities within an authorized laboratory environment.

Nmap was used to perform target discovery and service and version enumeration of the Metasploitable 2 system. The results provided information about exposed network services, ports, and software versions. Tenable Nessus was then installed and configured on Kali Linux and used to perform an automated vulnerability assessment against the authorized target.

The completed Nessus assessment identified **12 documented vulnerabilities**, consisting of **1 Critical, 5 High, and 6 Medium severity findings**. The findings were analyzed using vulnerability descriptions, CVE identifiers, CVSS scores, affected services, and Nessus plugin evidence. The important findings were also correlated with the Nmap service and version discovery results to improve confidence in the assessment.

The practical provided valuable hands-on experience in **network reconnaissance, service enumeration, vulnerability scanning, vulnerability analysis, risk assessment, evidence collection, finding verification, and remediation planning**.

Overall, this assignment strengthened practical cybersecurity skills and provided a better understanding of how tools such as Nmap and Nessus can be used together as part of a structured vulnerability assessment workflow. It also demonstrated the importance of verifying automated scanner results and developing appropriate remediation recommendations based on the identified security weaknesses.

## 16. REFERENCES

The following resources were consulted and used during the vulnerability assessment practical:

1. **Tenable Nessus Documentation** – Documentation related to Nessus installation, configuration, vulnerability scanning, plugin updates, scan execution, and vulnerability analysis.
2. **Nmap Documentation** – Documentation related to network discovery, port scanning, service detection, and version detection.
3. **Kali Linux Documentation** – Documentation related to the Kali Linux operating system, security tools, and penetration-testing environment.
4. **Metasploitable 2 Documentation** – Reference material for the intentionally vulnerable virtual machine used for cybersecurity training, vulnerability assessment, and security-testing practice.
5. **Common Vulnerabilities and Exposures (CVE)** – Reference information used for identifying and understanding publicly documented software vulnerabilities and their associated CVE identifiers.
6. **VMware Documentation** – Reference material related to virtual machine configuration, virtual networking, and laboratory environment setup.

These resources supported the practical activities involving network discovery, vulnerability scanning, vulnerability analysis, verification, risk assessment, and remediation planning.



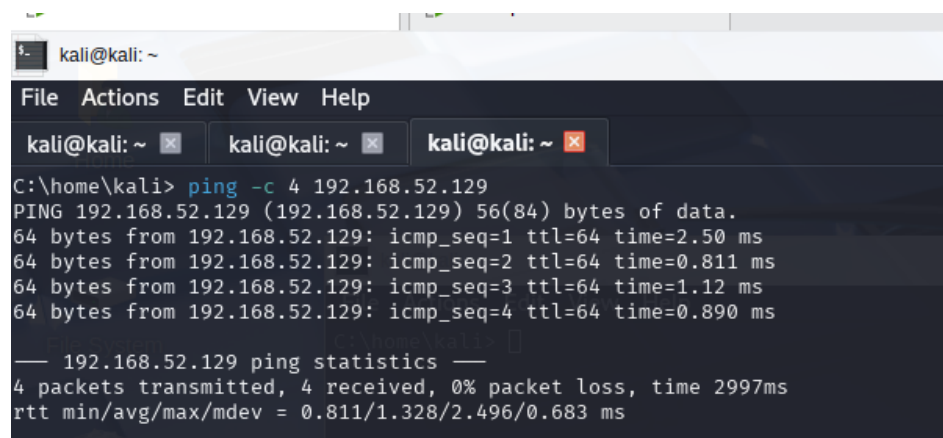
## 17. APPENDIX – SCREENSHOTS AND EVIDENCE

The following appendix provides a consolidated record of the screenshots and practical evidence collected during the Week 3 Vulnerability Assessment practical. The screenshots document the major stages of the assessment, including network verification, Nmap service discovery, Nessus installation and configuration, vulnerability scanning, finding analysis, verification, and remediation analysis.

### 17.1 Network Connectivity and Service Discovery

**Figure 1: Network Connectivity Verification Between Kali Linux and Metasploitable 2**

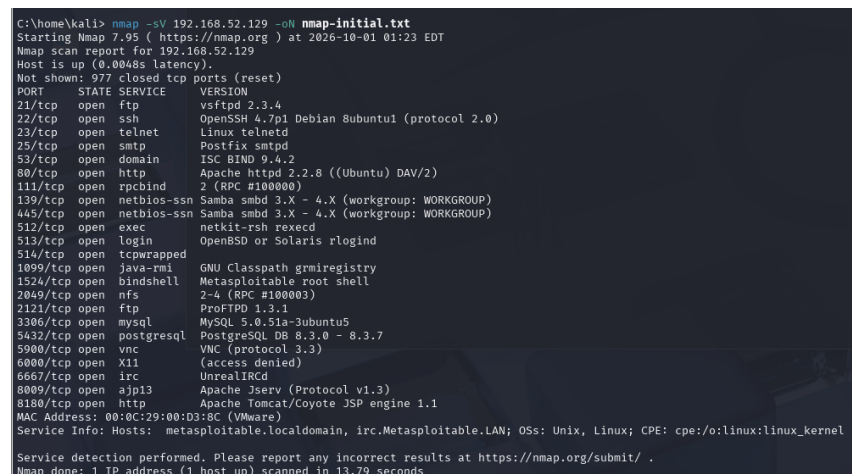
**Evidence:** Connectivity verification between the Kali Linux assessment machine and the authorized Metasploitable 2 target.



```
kali@kali: ~  
File Actions Edit View Help  
kali@kali: ~ x kali@kali: ~ x kali@kali: ~ x  
C:\home\kali> ping -c 4 192.168.52.129  
PING 192.168.52.129 (192.168.52.129) 56(84) bytes of data.  
64 bytes from 192.168.52.129: icmp_seq=1 ttl=64 time=2.50 ms  
64 bytes from 192.168.52.129: icmp_seq=2 ttl=64 time=0.811 ms  
64 bytes from 192.168.52.129: icmp_seq=3 ttl=64 time=1.12 ms  
64 bytes from 192.168.52.129: icmp_seq=4 ttl=64 time=0.890 ms  
  
— 192.168.52.129 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 2997ms  
rtt min/avg/max/mdev = 0.811/1.328/2.496/0.683 ms
```

**Figure 2: Nmap Service and Version Discovery Results**

**Evidence:** Nmap service and version discovery showing the exposed ports, services, and software versions on the Metasploitable 2 target.



```
C:\home\kali> nmap -sV 192.168.52.129 -oN nmap-initial.txt  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-01 01:23 EDT  
Nmap scan report for 192.168.52.129  
Host is up (0.0048s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rshcd  
513/tcp   open  login        OpenBSD or Solaris rlogind  
514/tcp   open  tcpwrapped  
1099/tcp  open  java-rmi     GNU Classpath gmrregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-k (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
6000/tcp  open  x11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
MAC Address: 00:0C:29:00:D3:8C (VMware)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 13.79 seconds
```

### 17.2 Nessus Installation and Configuration

### Figure 3: Nessus Installation and Service Verification

**Evidence:** Successful Nessus installation and verification of the Nessus service running on Kali Linux.

```
C:\home\kali> sudo systemctl status nessusd.service
● nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/usr/lib/systemd/system/nessusd.service; disabled; preset: disabled)
   Active: active (running) since Thu 2026-10-01 01:46:52 EDT; 19s ago
  Invocation: f05afa79da7740d18f1e51c48129bd43
    Main PID: 10026 (nessus-service)
      Tasks: 14 (limit: 2199)
     Memory: 86.4M (peak: 86.4M)
        CPU: 16.675s
    CGroup: /system.slice/nessusd.service
            └─10026 /opt/nessus/sbin/nessus-service -q
              └─10027 nessusd -q

Oct 01 01:46:52 kali systemd[1]: Started nessusd.service - The Nessus Vulnerability Scanner.
Oct 01 01:46:52 kali nessus-service[10026]: nessus-service [10026][INFO] : Nessus 19.18.4 [build 20038] Started
```

### Figure 4: Nessus Plugin Update Completion

**Evidence:** Successful completion of the Nessus plugin update before vulnerability scanning.

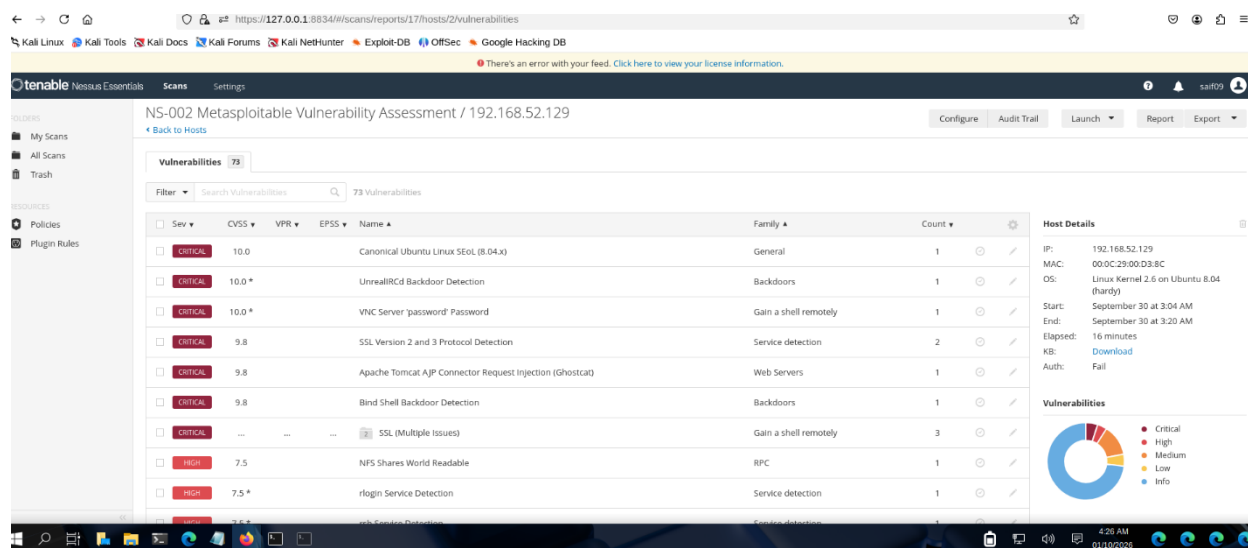
```
File Actions Edit View Help

C:\home\kali> sudo /opt/nessus/sbin/nessuscli update --plugins-only
Refreshing Nessus license information... complete; continuing with updates.

— Fetching the newest updates from nessus.org —
```

### Figure 5: Nessus Vulnerability Scan Configuration

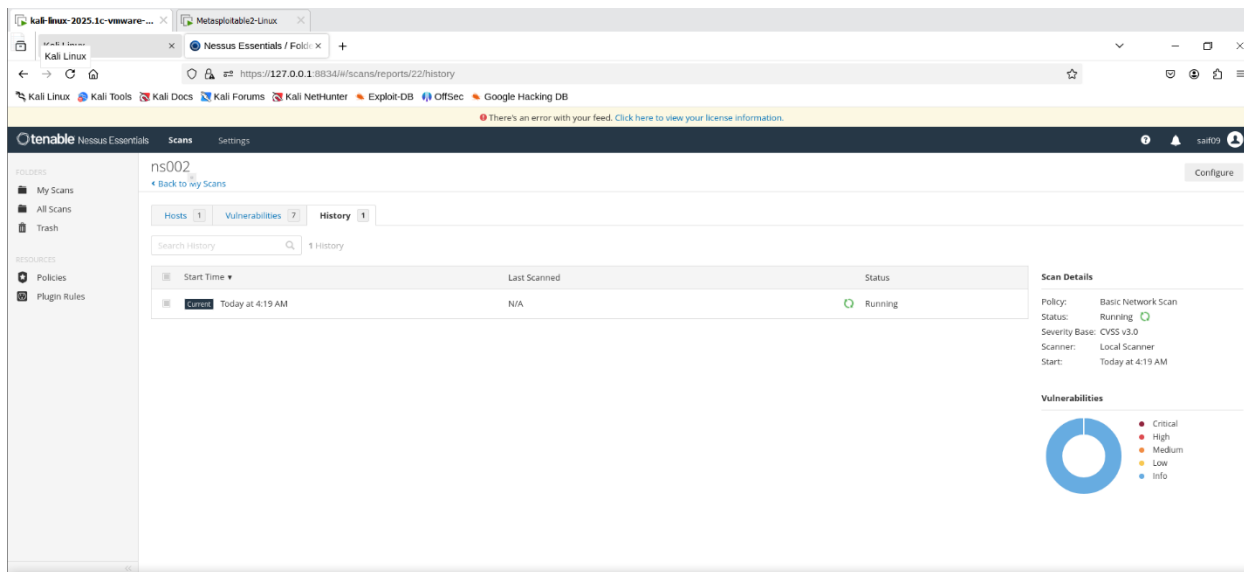
**Evidence:** Nessus scan configuration showing the Metasploitable 2 target and selected scan settings.



## 17.3 Nessus Vulnerability Assessment

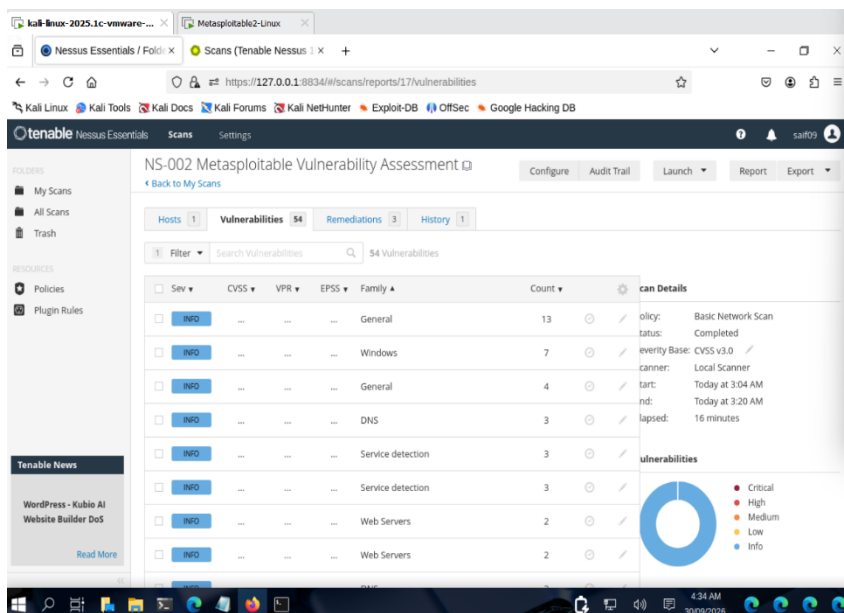
**Figure 6: Nessus Vulnerability Scan in Progress**

**Evidence:** Nessus vulnerability assessment running against the authorized Metasploitable 2 target.



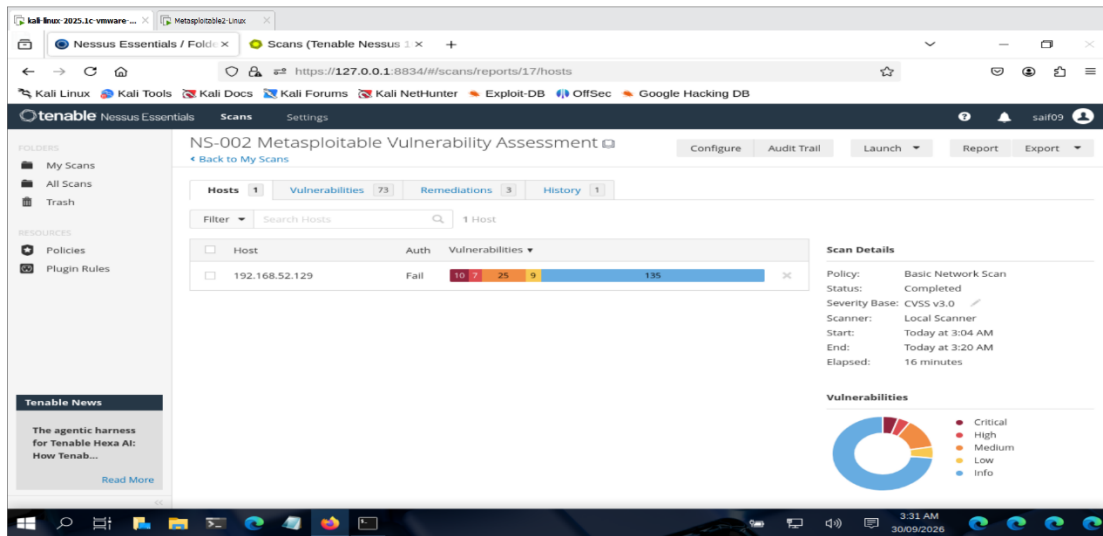
**Figure 7: Completed Nessus Vulnerability Scan Results**

**Evidence:** Completion of the Nessus vulnerability assessment and availability of the scan results.



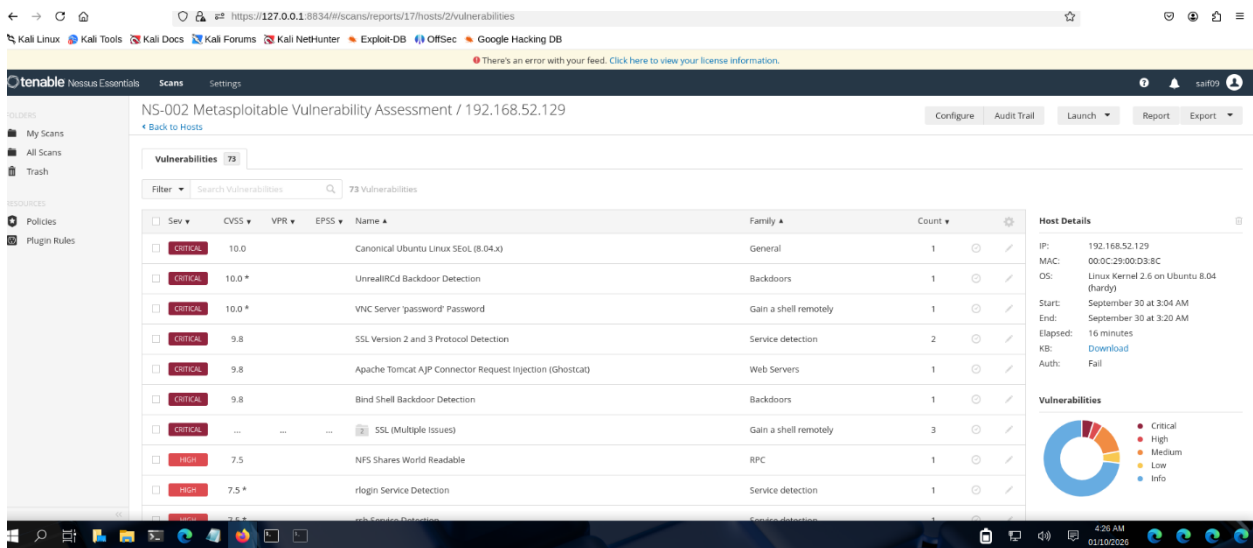
**Figure 8: Nessus Vulnerability Findings and Severity Summary**

**Evidence:** Nessus vulnerability results showing the identified findings and their severity classifications.



**Figure 9: Nessus Detailed Vulnerability Findings**

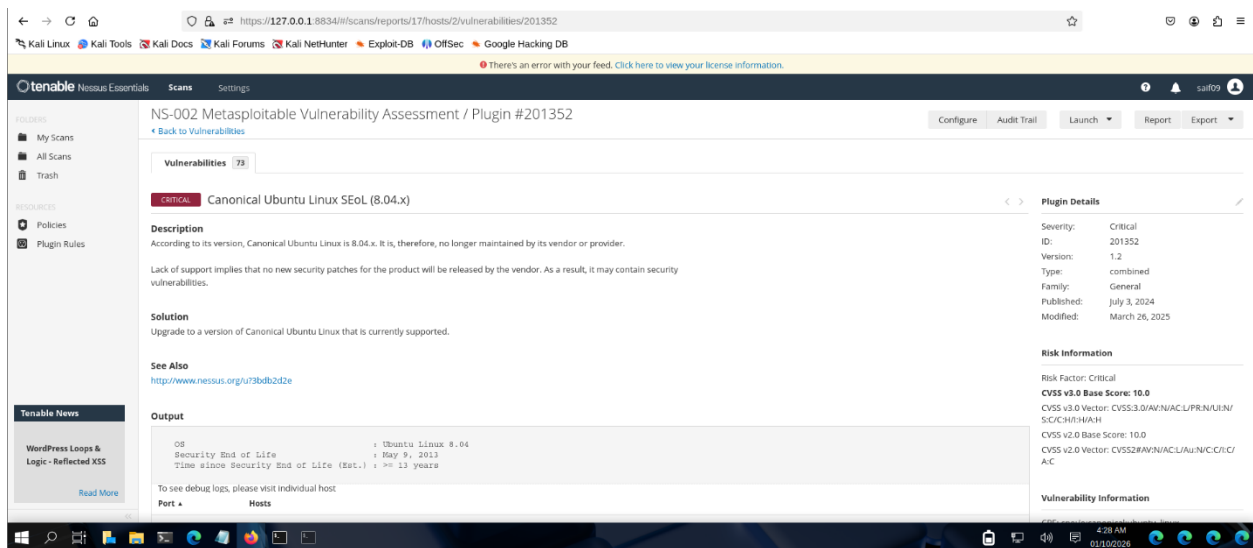
**Evidence:** Detailed Nessus vulnerability findings containing vulnerability names, severity levels, CVSS information, and affected services.



## 17.4 Finding Verification

**Figure 22: Verification of Nessus Findings Using Nmap Service and Version Information**

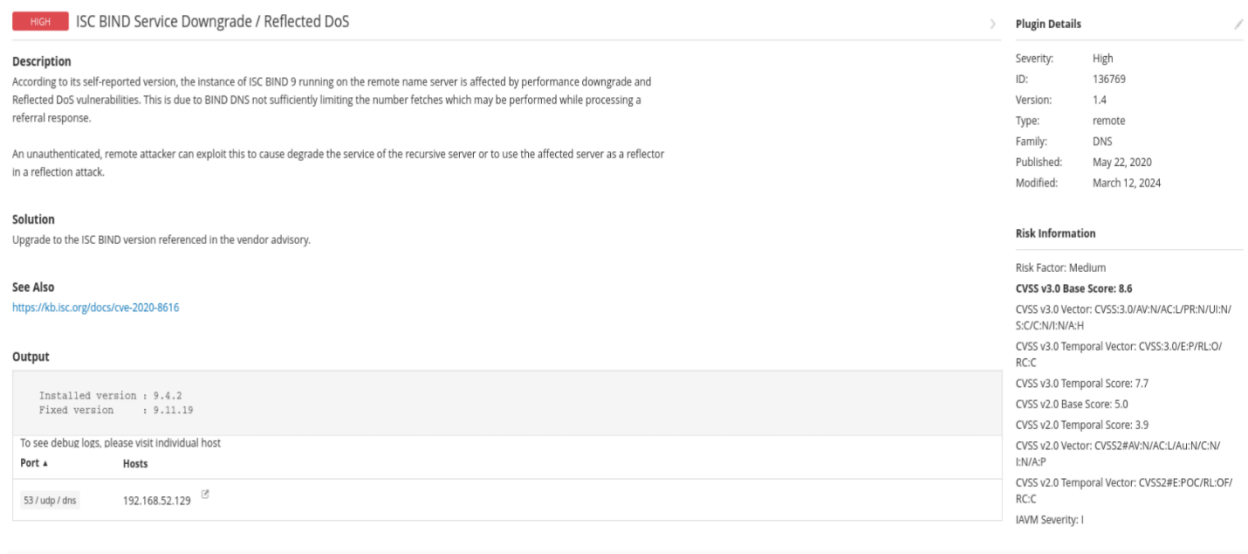
**Evidence:** Nmap service and version information used to correlate Nessus findings with services exposed on the authorized target.



## 17.5 Risk Analysis Evidence

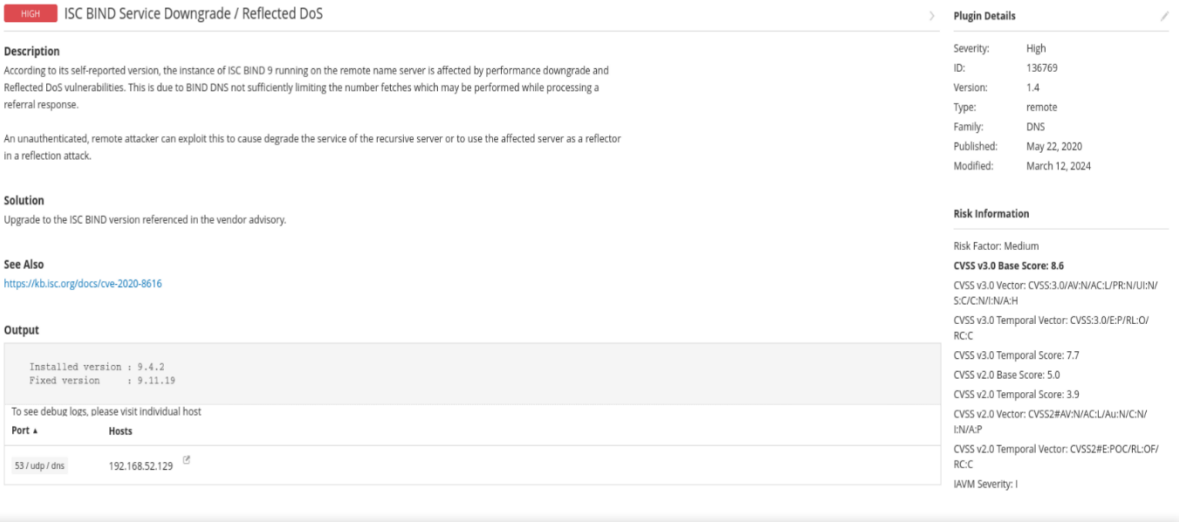
### Figure 23(a): Nessus Critical Severity Vulnerability

**Evidence:** Nessus result showing the Critical severity finding.



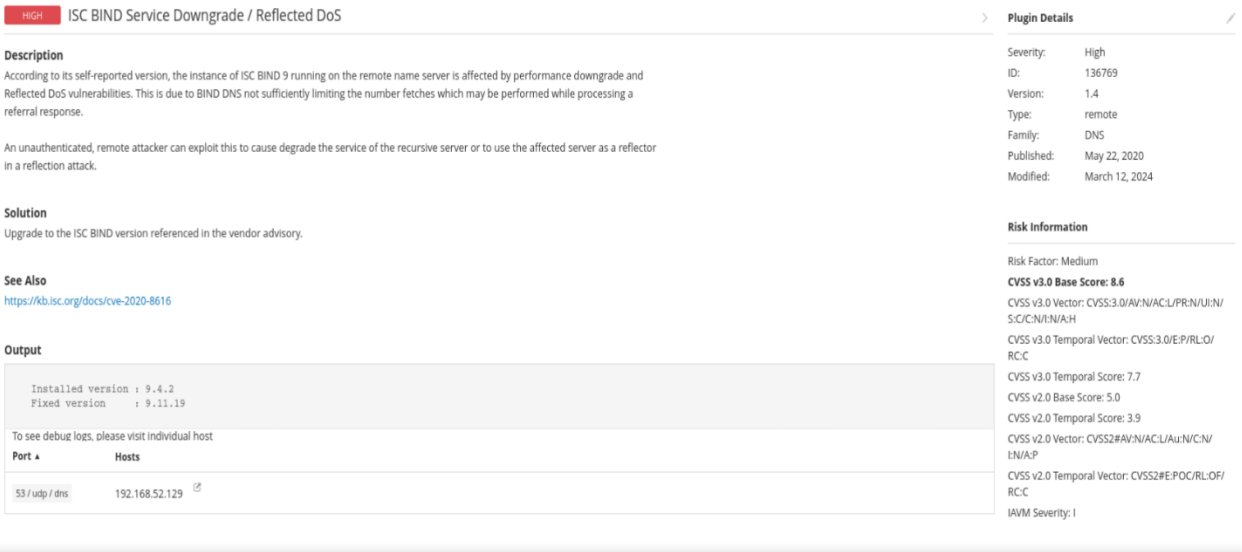
### Figure 23(b): Nessus High Severity Vulnerabilities

**Evidence:** Nessus results showing the High severity findings.



**Figure 23(c): Nessus Medium Severity Vulnerabilities**

**Evidence:** Nessus results showing the Medium severity findings.



## 17.6 Remediation Analysis Evidence

**Figure 24: Nessus Vulnerability Details Used for Remediation Analysis**

**Evidence:** Nessus plugin details showing vulnerability information and remediation/solution information used to prepare the recommendations.

HIGH

ISC BIND Service Downgrade / Reflected DoS

Description

According to its self-reported version, the instance of ISC BIND 9 running on the remote name server is affected by performance downgrade and Reflected DoS vulnerabilities. This is due to BIND DNS not sufficiently limiting the number fetches which may be performed while processing a referral response.

An unauthenticated, remote attacker can exploit this to cause degrade the service of the recursive server or to use the affected server as a reflector in a reflection attack.

Solution

Upgrade to the ISC BIND version referenced in the vendor advisory.

See Also

<https://kb.isc.org/docs/cve-2020-8616>

Output

Installed version : 9.4.2  
Fixed version : 9.11.19

To see debug logs, please visit individual host

| Port           | Hosts          |
|----------------|----------------|
| 53 / udp / dns | 192.168.52.129 |

Plugin Details

Severity: High

ID: 136769

Version: 1.4

Type: remote

Family: DNS

Published: May 22, 2020

Modified: March 12, 2024

Risk Information

Risk Factor: Medium

CVSS v3.0 Base Score: 8.6

CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:N/A:H

CVSS v3.0 Temporal Vector: CVSS:3.0/E:P/RL:O/RCC

CVSS v3.0 Temporal Score: 7.7

CVSS v2.0 Base Score: 5.0

CVSS v2.0 Temporal Score: 3.9

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:N/I:N/A:P

CVSS v2.0 Temporal Vector: CVSS2#E:POC/RL:OF/RCC

IAWM Severity: I

## 17.7 Evidence Summary

The screenshots included in this appendix provide supporting evidence for the practical activities documented throughout the report. The evidence demonstrates the progression from network connectivity verification and service discovery to Nessus configuration, vulnerability scanning, finding verification, risk analysis, and remediation planning.

All screenshots should represent the **actual activities performed during the laboratory practical**. No fabricated or simulated evidence should be included in the final report.